

Darshana Opticals (Pvt) Ltd.
Software Design Specification (SDS)

By

D.S.U. WEERAKKODY

SE/2021/018

T.H. IMASHA

SE/2021/053

SANDARU MIHIRAN

SE/2021/010

E.K.A.K. AMALKA

SE/2021/008

**A report submitted in partial fulfillment of the requirements for the degree of
Bachelor of Science Honors in Software Engineering (B.Sc.SE)**

Software Engineering Teaching Unit

Faculty of Science

University of Kelaniya

Sri Lanka

2026

Version History

Version No.	Date	Author(s)	Summary of Changes
1.0	19.04.2026	Sachini Weerakkody Hiruni Imasha Sandaru Mihiran Kavindu Amalka	Initial SDS draft

Table of Contents

Chapter 1: Architectural Design	1
1.1 System Context Diagram	1
1.2 High-level Architecture	1
1.2.1 Detailed Description of Layers	2
1.3 Cloud-Native Architecture	3
1.4 Justification for Architecture Choice	4
1.4.1 Architecture	4
1.4.2 AWS cloud-native	5
1.5 Scalability & Maintainability Considerations	6
1.5.1 Scalability	6
1.5.2 Maintainability	6
Chapter 2: Database Design	8
2.1 ER Diagram	8
2.2 Normalization Explanation	9
Chapter 3: Class Diagram	13
Chapter 4: Sequence Diagrams	14
4.1 User Visit and Homepage	14
4.2 Authentication (Register and Login)	15
4.3 Product Discovery (Search, Filter, Detail)	16
4.4 Cart Management	17
4.5 Checkout and Order Confirmation	18
4.6 Appointment Booking	19
4.7 Chatbot Interaction	20
Chapter 5: UI/UX Design	21
5.1 Screen Mock-ups for Key User Interfaces	21
5.2 User flow / Navigation Diagrams	42
5.3 Accessibility Considerations	49
Chapter 6: Security Design	54
6.1 Authentication Mechanism	54
6.2 Authorization Levels	55
6.3 Data Protection Approach	58

6.4 Input Validation and Sanitization Strategy	60
6.5 Encryption Standards for Data at Rest and in Transit	61
Chapter 7: Deployment Design	63
7.1 Hosting Plan.....	63
7.2 Hardware Requirements	64
7.3 Network Diagram	65
7.4 Environment Specification	67
7.5 CI/CD Pipeline Overview.....	69
Chapter 8: References	71

List of Tables

Table 1: Customer Table	10
Table 2: Staff Table	10
Table 3: Admin Table.....	10
Table 4: Branch Table	10
Table 5: Inventory Table	11
Table 6: Order Table.....	11
Table 7: Order Item Table	11
Table 8: Payment Table.....	11
Table 9: Appointment Table.....	11
Table 10: Chatbot Table	12
Table 11: Knowledge Area Table.....	12
Table 12: Updated Access Control Matrix Table.....	56
Table 13: Environment Comparison Table	69

Table of Figures

Figure 1: System Context Diagram.....	1
Figure 2: Architecture Diagram.....	1
Figure 3: ER Diagram	8
Figure 4: Class Diagram	13
Figure 5: User Visit and Home Page Sequence Diagram	14
Figure 6: Authentication Sequence Diagram	15
Figure 7: Product Discovery Sequence Diagram	16
Figure 8: Cart Management Sequence Diagram	17
Figure 9: Checkout and Order Confirmation Sequence Diagram	18
Figure 10: Appointment Booking Sequence Diagram	19
Figure 11: Chatbot Interaction Sequence Diagram	20
Figure 12: Landing Page	22
Figure 13: Sign Up Page	23
Figure 14: Login Page	23
Figure 15: Profile Page	24
Figure 16: Home Page	25
Figure 17: Men's Collection Page	26
Figure 18: Women's Collection Page.....	27
Figure 19: Kids' Collection Page	28
Figure 20: Sunglasses Collection Page	29
Figure 21: Product Information Page	30
Figure 22: Cart Drawer.....	31
Figure 23: Shipping Information Page.....	32
Figure 24: Payment Details Page.....	33
Figure 25: Order Review Page	34
Figure 26: Order Confirmation Page	35
Figure 27: Patient Details Page	36
Figure 28: Doctor Selection Page	37
Figure 29: Appointment Scheduling Page.....	38
Figure 30: Appointment Review Page.....	39
Figure 31: Appointment Confirmation Page.....	40
Figure 32: Chatbot Widget.....	41
Figure 33: Role-Based User Flow.....	42
Figure 34: Browse and Product Discovery Flow	43
Figure 35: Cart Management Flow	44
Figure 36: Checkout and Order Confirmation Flow.....	45
Figure 37: User Profile Management Flow	46

Figure 38: Authentication Flow..... 47

Figure 39: Appointment Booking Flow 48

Figure 40: Chatbot Interaction Flow 49

Figure 41: Network Diagram 67

Chapter 1: Architectural Design

1.1 System Context Diagram

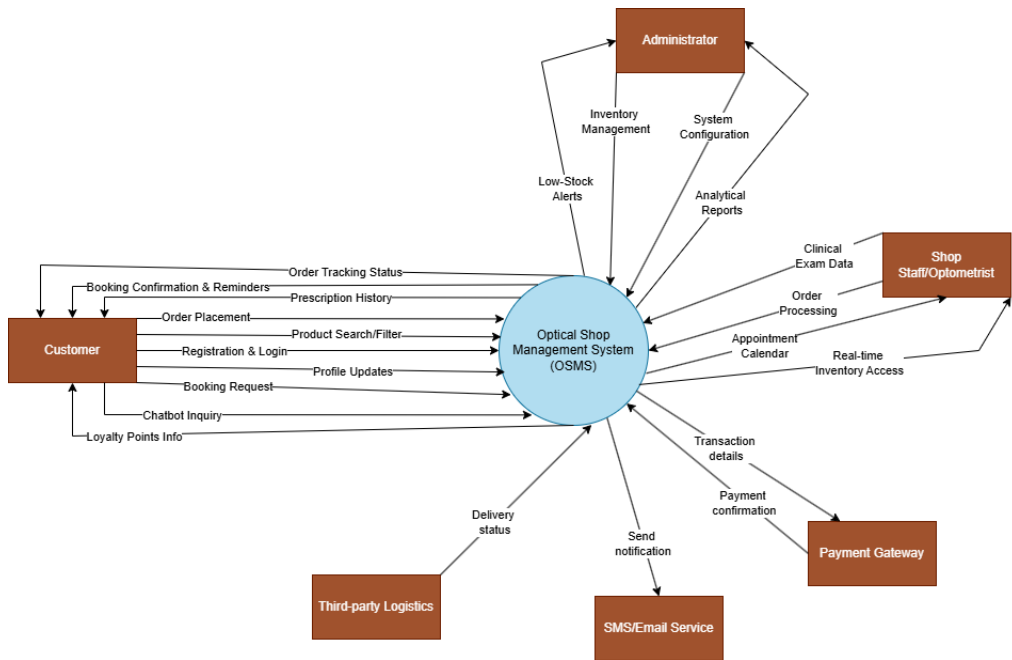


Figure 1: System Context Diagram

1.2 High-level Architecture

High-Level 3-Tier Architecture (MERN Stack)

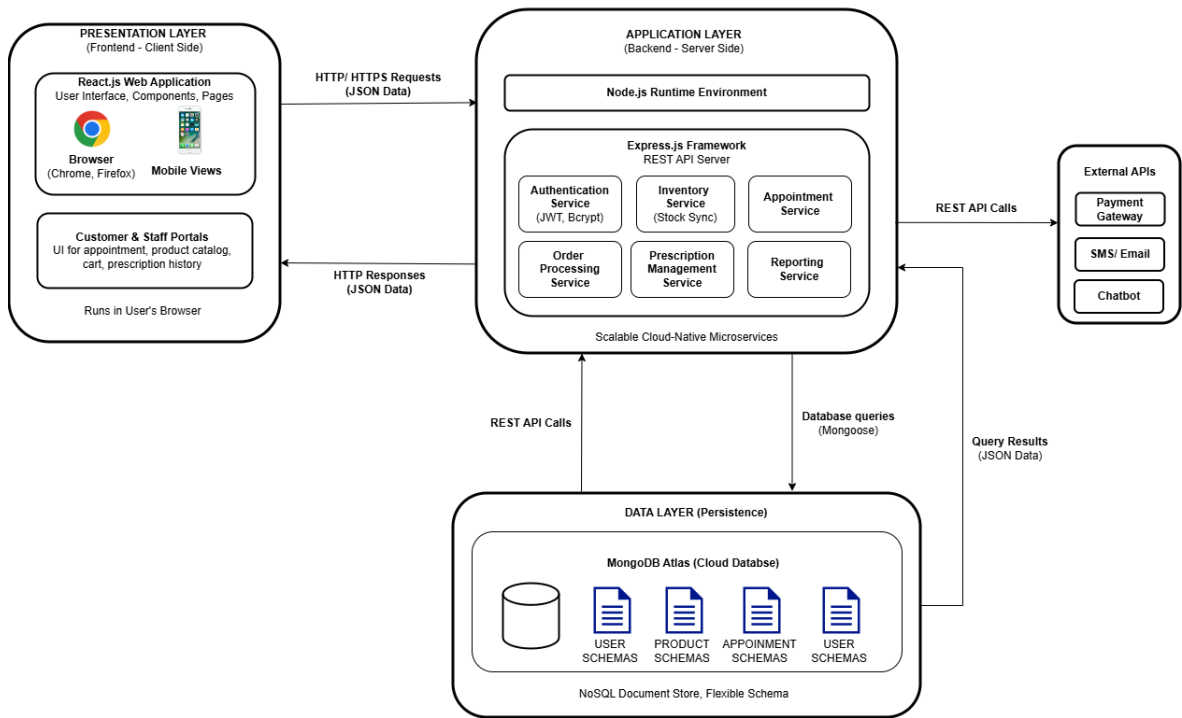


Figure 2: Architecture Diagram

1.2.1 Detailed Description of Layers

The Optical Shop Management System (OSMS) is designed using a 3-Tier Layered Architecture based on the MERN Stack (MongoDB, Express.js, React.js, and Node.js). This structural pattern ensures a clean separation of concerns, facilitating high maintainability, independent layer scalability, and robust security.

1. Presentation Layer (Frontend - React.js)

- **Role:** The topmost layer of architecture, responsible for the User Interface (UI) and User Experience (UX).
- **Technologies:** Developed using React.js, ensuring a responsive and modern Single Page Application (SPA).
- **Functionality:**
 - Provides dedicated portals for Customers, Shop Staff, and Administrators.
 - Handles client-side routing, form validation, and state management for features such as the digital product catalog (FR-003) and the interactive appointment calendar (FR-007).
 - Communicates with the Application Layer via asynchronous RESTful API calls using JSON data format.

2. Application Layer (Backend - Node.js & Express.js)

- **Role:** Known as the "Business Logic Layer," this tier acts as the intermediary that processes requests, enforces business rules, and manages data flow between the UI and the Database.
- **Technologies:** Powered by Node.js as the runtime environment and Express.js as the web application framework.
- **Functionality:**
 - **Authentication & Security:** Implements secure user sessions and access control using JWT (JSON Web Tokens) and Bcrypt password hashing (FR-001).

- Business Logic Execution: Processes core functions such as real-time inventory synchronization (FR-005), automated re-order alerts (FR-006), and loyalty point calculations (FR-010).
- Integration Services: Manages external interfaces with third-party providers for Payment Gateways (FR-009) and SMS/Email notification services (FR-008).

3. Data Layer (Persistence - MongoDB)

- Role: This layer is responsible for the permanent storage, retrieval, and management of all system data.
- Technologies: Utilizes MongoDB Atlas, a cloud-based NoSQL document database.
- Functionality:
 - Flexible Schema: Uses a document-based structure to handle diverse data entities, including complex eyewear specifications and detailed clinical prescription histories (FR-013).
 - Data Consistency: Ensures real-time data synchronization across all physical branches to prevent stock conflicts.
 - Security & Compliance: Maintains encrypted data storage and historical archives for seven years to meet regulatory and auditing requirements.

1.3 Cloud-Native Architecture

The OSMS architecture is designed to be Cloud-Native, leveraging Amazon Web Services (AWS) to ensure high availability, security, and effortless scaling. The system follows a modular deployment strategy using containerized services to support the operational demands of Darshana Optical Pvt Ltd.

Core AWS Infrastructure Components

- Networking & Security (AWS Route 53 & WAF):
 - AWS Route 53 handles Domain Name System (DNS) management for reliable routing of user traffic.
 - AWS WAF (Web Application Firewall) protects the system from common web exploits and unauthorized access attempts.

- **Compute Tier (AWS ECS with Fargate):**
 - The Node.js/Express.js backend and React.js frontend are containerized using Docker and managed by Amazon ECS (Elastic Container Service).
 - AWS Fargate is utilized as a serverless compute engine to eliminate the need for manual server management while scaling automatically based on traffic.
- **Storage Tier (AWS S3 & MongoDB Atlas):**
 - Amazon S3 (Simple Storage Service): Used as high-durability object storage for eyewear product images and digital copies of customer prescriptions.
 - MongoDB Atlas (on AWS): A fully managed cloud database instance hosted on AWS to provide real-time synchronization of inventory and clinical data across all branches.
- **Content Delivery & Load Balancing (AWS CloudFront & ALB):**
 - AWS CloudFront (CDN): Ensures fast delivery of static assets (CSS, JS, Images) to users with low latency.
 - Application Load Balancer (ALB): Distributes incoming application traffic across multiple containers to ensure no single instance is overwhelmed, maintaining the 2-second response time requirement.
- **Communication & Notifications (AWS SES/SNS):**
 - Amazon SES (Simple Email Service) or SNS (Simple Notification Service) is integrated to dispatch automated appointment reminders and order updates to customers.

1.4 Justification for Architecture Choice

1.4.1 Architecture

The selection of a 3-Tier Layered Architecture for the Optical Shop Management System (OSMS) is strategically based on the following technical and operational requirements identified in the SRS:

- **Separation of Concerns (SoC):** By isolating the Presentation, Application, and Data layers, the system ensures that changes in one layer (e.g., updating the React UI) have

minimal impact on others (e.g., the backend business logic). This enhances the modularity of the OSMS.

- **Scalability for Growth:** The system is required to support a 50% increase in concurrent users without performance loss. This architecture allows for Independent Scaling, where the backend API instances can be scaled horizontally on AWS without needing to duplicate the frontend assets or the database.
- **Real-time Data Synchronization:** To ensure real-time inventory visibility across all branches (FR-005), a centralized Application Layer is essential to handle high-concurrency requests and maintain data integrity between physical stores and the digital storefront.
- **Enhanced Security & Compliance:** The layered approach allows for robust security at each tier. Sensitive clinical data and eye prescriptions (FR-013) are protected in the Data Layer behind a private subnet, while the Application Layer enforces mandatory authentication (JWT) for all requests, ensuring compliance with PDPA standards.
- **Optimized Development & Maintenance:** Using a unified language (JavaScript) across all layers (MERN stack) reduces the technical barrier for developers and streamlines the implementation of complex business rules, such as loyalty point calculations (FR-010) and automated re-order alerts (FR-006).
- **Improved Fault Tolerance:** Since the layers are decoupled, failure in the UI does not necessarily lead to data corruption or backend crashes. This supports the 99.9% uptime reliability requirement essential for Darshana Optical's business operations.

1.4.2 AWS cloud-native

1. **Scalability:** AWS Auto-scaling groups allow the system to handle the projected 50% increase in concurrent transactions seamlessly.
2. **Security Compliance:** Using AWS managed services ensures compliance with PCI DSS for payment processing and PDPA for medical data protection through integrated encryption (AWS KMS).
3. **Reliability:** The multi-Availability Zone (AZ) deployment ensures that if one data center fails, the system automatically fails over to another, maintaining the 99.9% uptime goal.

1.5 Scalability & Maintainability Considerations

To meet the high-performance standards and the six-month delivery schedule defined in the SRS, the OSMS architecture incorporates specific strategies to ensure the system remains robust as business demands grow.

1.5.1 Scalability

The system is designed to handle a projected 50% increase in concurrent users and transactions without performance degradation.

- **Horizontal Scaling (Stateless Backend):** The Node.js API is designed to be stateless, allowing multiple instances to run behind an AWS Application Load Balancer (ALB). This ensures that as traffic increases, additional containers can be launched automatically via AWS Fargate.
- **Database Scalability:** By utilizing MongoDB Atlas, the system benefits from "Sharding" and "Replica Sets," which distribute data across multiple clusters to maintain fast query response times (under 2 seconds) even as the data volume grows.
- **Asynchronous Processing:** High-latency tasks, such as sending automated SMS/Email reminders, are handled asynchronously to ensure the main application thread remains responsive for critical retail transactions.
- **Content Delivery Network (CDN):** AWS CloudFront is used to cache static assets (images, CSS, JS) at edge locations, reducing the load on the origin server and improving page load speeds for global or regional access.

1.5.2 Maintainability

The codebase is structured to ensure that 90% of minor bug fixes can be deployed within 24 hours.

- **Modular Architecture:** The system is divided into independent modules (e.g., Inventory, Appointments, and User Management). This allows developers to update or fix a specific module without affecting the entire system's stability.
- **Unified Technology Stack:** Utilizing the MERN stack (JavaScript/TypeScript) across both frontend and backend reduces context switching for developers and simplifies the hiring and training process for new staff.

- Automated Documentation & Clean Code: Following strict IEEE documentation standards and maintaining thorough code documentation (RSK-003) ensures that knowledge sharing is seamless and reduces technical debt.
- Centralized Logging and Monitoring: Cloud-native monitoring tools are integrated to track system health in real-time, allowing for proactive identification of errors before they impact the end-user.
- CI/CD Pipeline: A Continuous Integration and Continuous Deployment (CI/CD) pipeline is established to automate testing and deployment, ensuring that updates follow a standardized, error-free path to the production environment.

Chapter 2: Database Design

2.1 ER Diagram

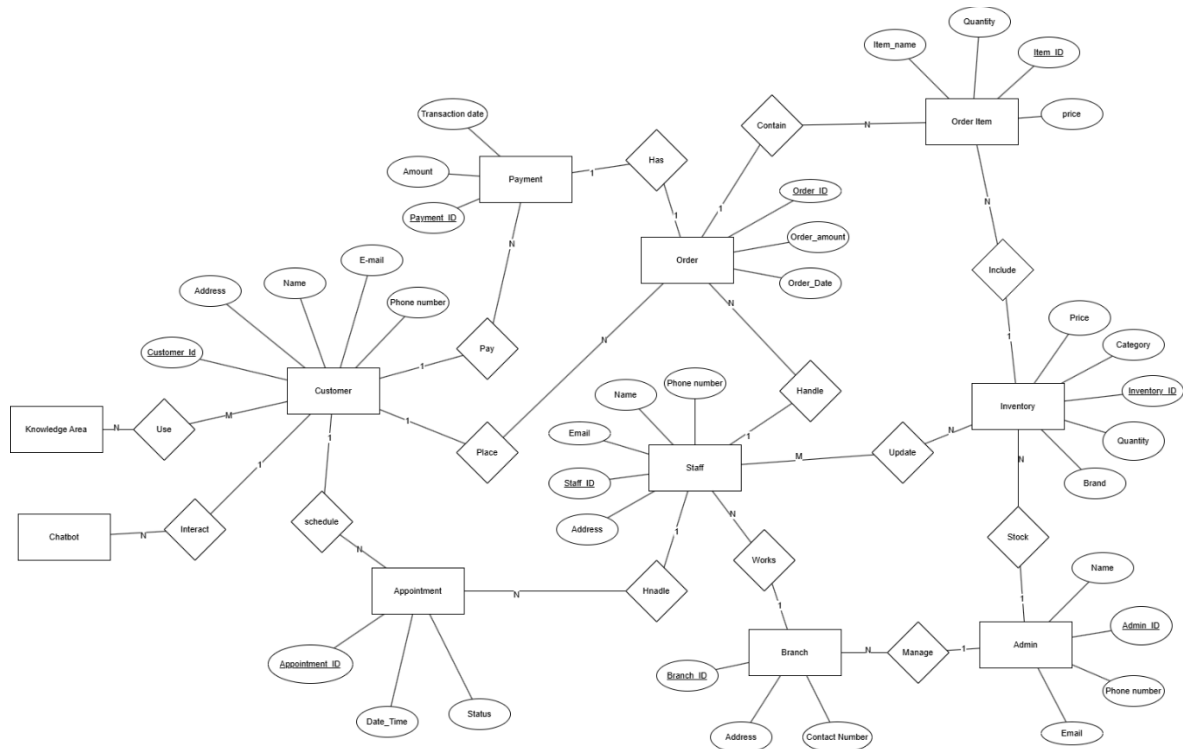


Figure 3: ER Diagram

- * A centralized database architecture was designed to maintain data integrity across all branches.
- * A One-to-Many (1: N) relationship was established between the Branch and Staff entities to represent employee assignments within specific locations.
- * Transactional data was captured through the Order and Order Item entities, ensuring that multiple products can be included in a single purchase.
- * Appointment scheduling was automated by linking Customer, Staff, and Appointment entities, allowing for efficient status tracking and manual intervention where necessary.
- * The Inventory entity was structured to be managed by the admin, enabling real-time stock updates across the multi-branch network.

2.2 Normalization Explanation

The database schema of the Optical Shop Management System (OSMS) was subjected to a rigorous normalization process to ensure data integrity, minimize redundancy, and prevent update anomalies. Although the system is developed using the MERN stack, the logical data model was refined through the following normalization stages:

First Normal Form (1NF)

- Atomicity of data was ensured by removing multi-valued attributes and ensuring that each field contains only a single, atomic value.
- Unique identification for each record was established through the assignment of Primary Keys, such as `Customer_Id`, `Staff_Id`, and `Inventory_Id`.
- Repeating groups within entities, particularly in the Order Item and Inventory tables, were eliminated to maintain a flat data structure.

Second Normal Form (2NF)

- All partial functional dependencies were removed to ensure that every non-key attribute is fully functionally dependent on the primary key.
- For instance, attributes such as Brand and Category were linked specifically to the `Inventory_Id` within the Inventory entity, ensuring that they do not depend on only a part of a composite key.
- Separate entities were created for Payment and Order to decouple transaction details from payment status, thereby adhering to 2NF requirements.

Third Normal Form (3NF)

- Transitive dependencies were eliminated to ensure that non-key attributes do not depend on other non-key attributes.
- Within the Customer entity, attributes like Address and Phone Number were directly mapped to the `Customer_Id`, ensuring that no indirect dependencies exist.
- The Branch information was isolated into its own entity, so that staff-related data and branch-specific details (like Contact Number and Location) are maintained independently, preventing data from being inconsistent during staff updates.

Final Normalized Database Schema (3NF)

The following tables represent the final database structure after eliminating all redundancies and dependencies.

User & Customer Entities

Customer

Table 1: Customer Table

<u>Customer_Id</u>	Name	E-mail	Address	Phone_number

Staff

Table 2: Staff Table

<u>Staff_ID</u>	Branch_ID	Name	Email	Phone_number	Address

Admin

Table 3: Admin Table

<u>Admin_ID</u>	Name	Email	Phone_number

Inventory & Branch Entities

Branch

Table 4: Branch Table

<u>Branch_ID</u>	Address	Contact_Number

Inventory

Table 5: Inventory Table

<u>Inventory_ID</u>	Branch_ID	Item_Name	Category	Brand	Price	Quantity

Transactional Entities

Order

Table 6: Order Table

<u>Order_ID</u>	Customer_Id	Order_Date	Order_amount

Order Item

Table 7: Order Item Table

<u>Item_ID</u>	Order_ID	Item_name	Price	Quantity

Payment

Table 8: Payment Table

<u>Payment_ID</u>	Order_ID	Amount	Transaction_date

Service & Support Entities

Appointment

Table 9: Appointment Table

<u>Appointment_ID</u>	Customer_Id	Staff_ID	Date_Time	Status

Chatbot

Table 10: Chatbot Table

<u>Chat_ID</u>	Customer_Id	Inquiry_Type	Response_Status

Knowledge Area

Table 11: Knowledge Area Table

<u>Article_ID</u>	Category	Content_Title

Chapter 3: Class Diagram

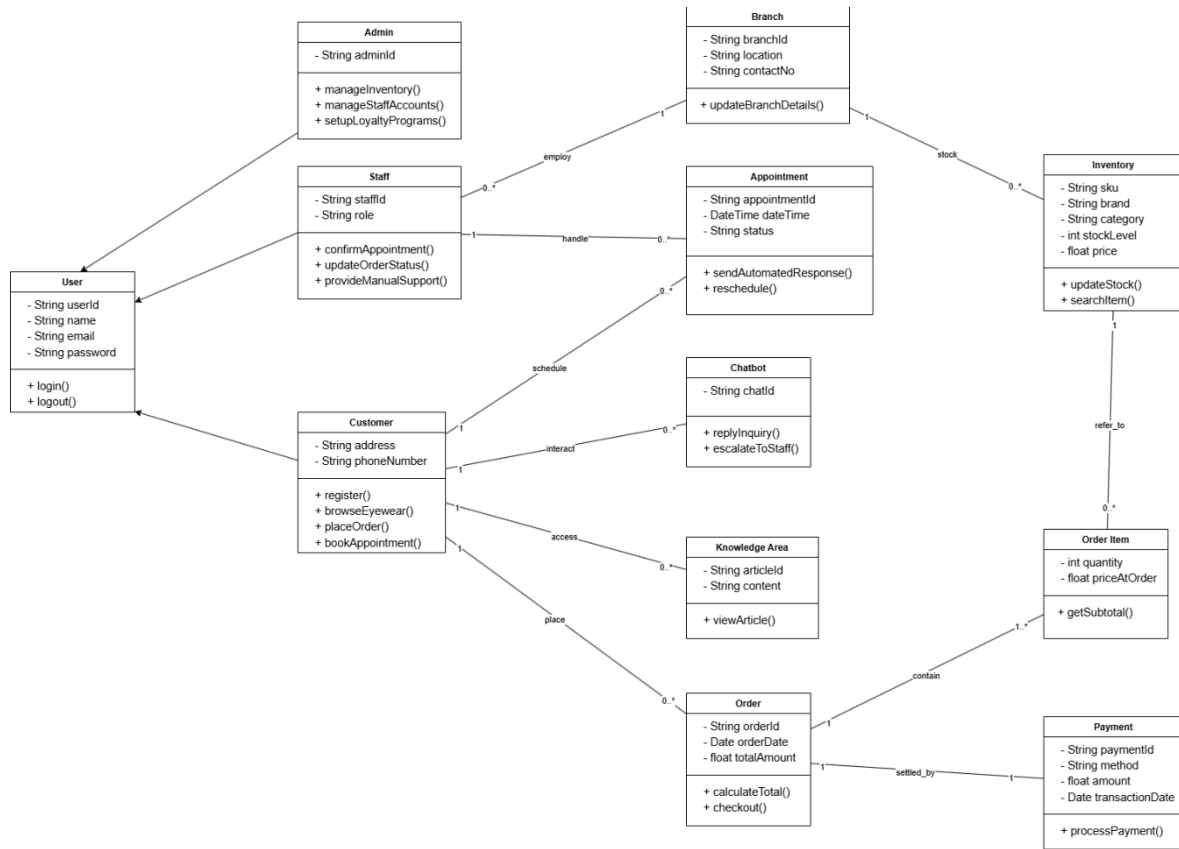


Figure 4: Class Diagram

Attribute and Method Visibility: All internal data fields were designated as private (-), while functional operations such as `register()` and `updateStock()` were assigned public visibility (+) to facilitate inter-class communication.

Association and Multiplicity: Relationships between classes were formally defined, such as the One-to-Many (1..*) association between the Customer and Order classes, ensuring that multiple transactions can be linked to a single user.

Inheritance and Roles: Specific roles for Staff and Admin were established to define access levels within the system, aligning with the user role identification process.

System Automation: Methods like `sendAutomatedResponse()` in the Appointment class were incorporated to represent the automated feedback loop identified in the system process flow.

Chapter 4: Sequence Diagrams

4.1 User Visit and Homepage

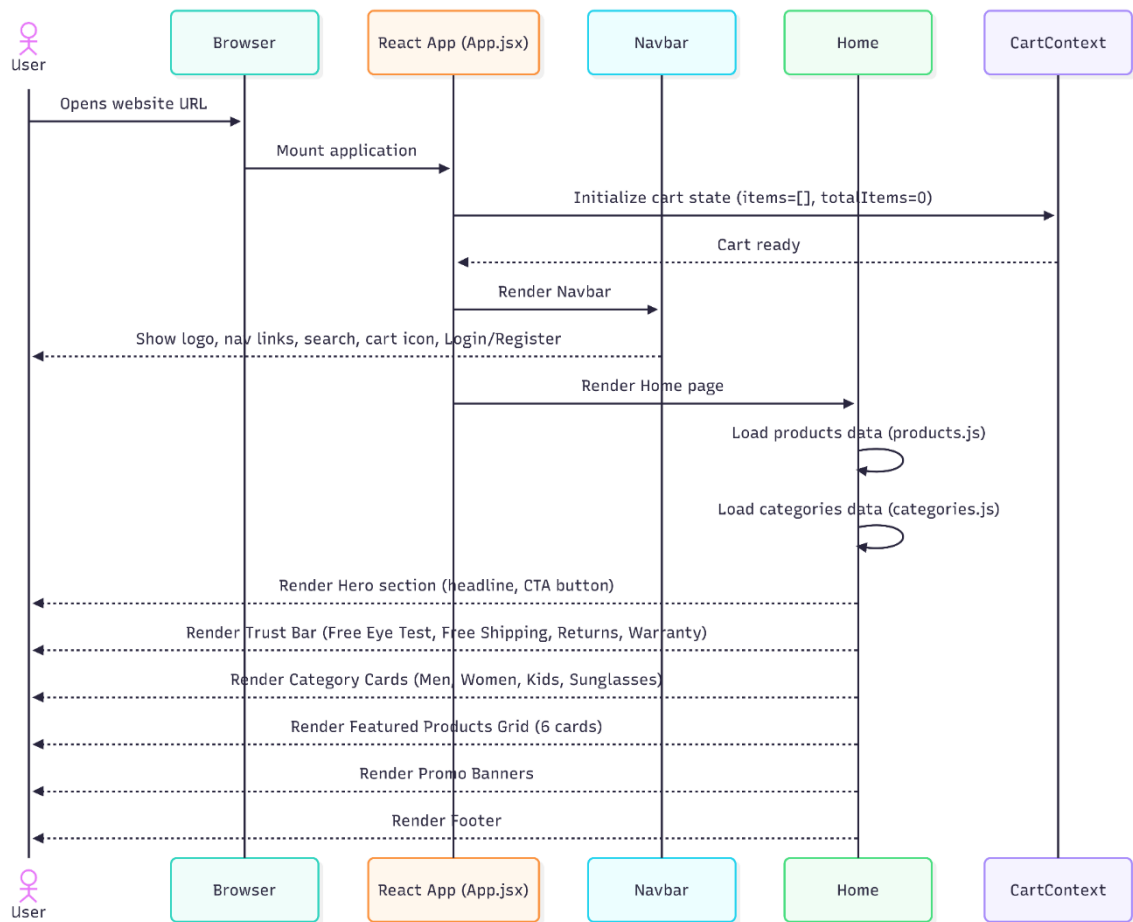


Figure 5: User Visit and Home Page Sequence Diagram

4.2 Authentication (Register and Login)

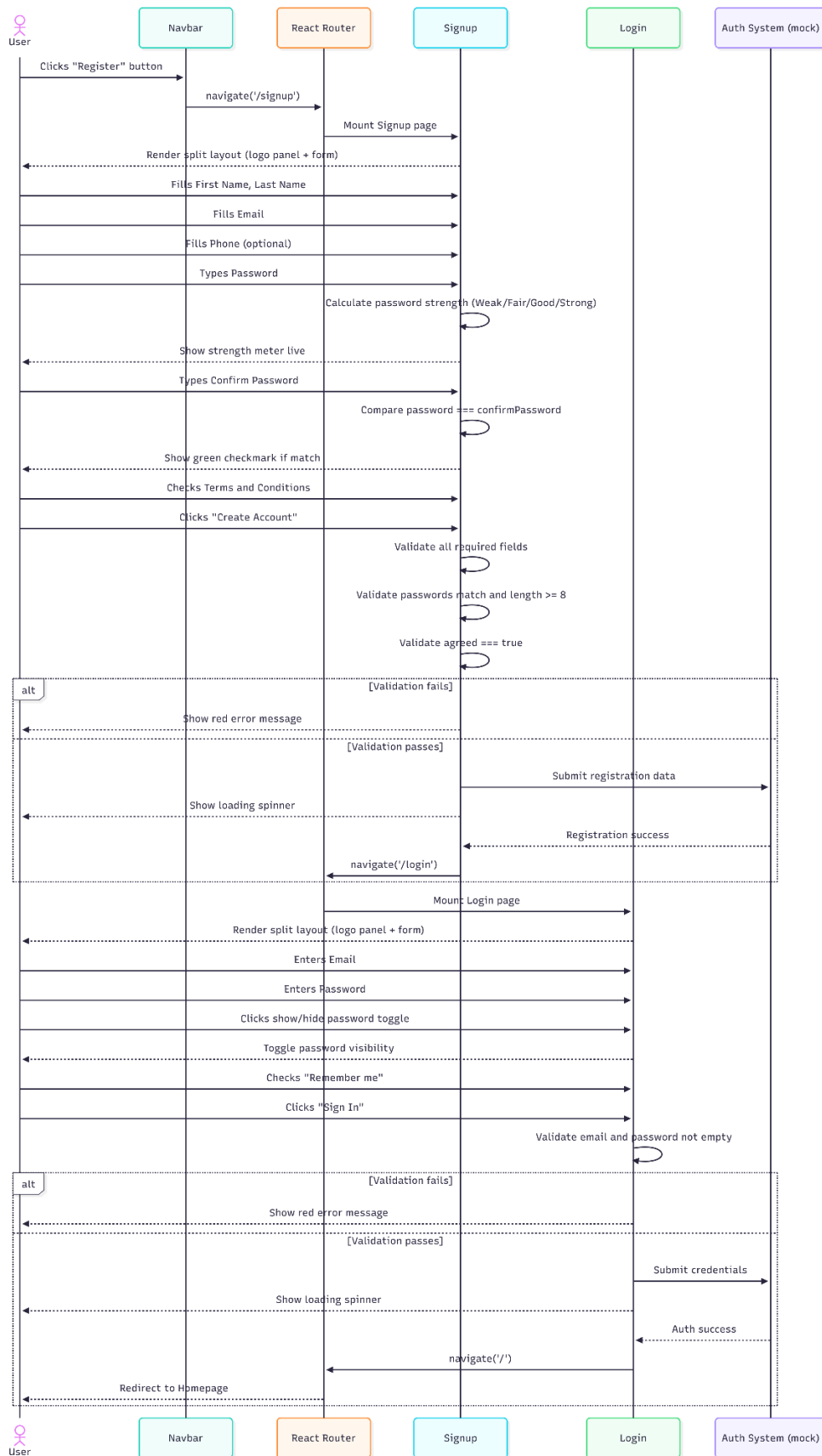


Figure 6: Authentication Sequence Diagram

4.3 Product Discovery (Search, Filter, Detail)

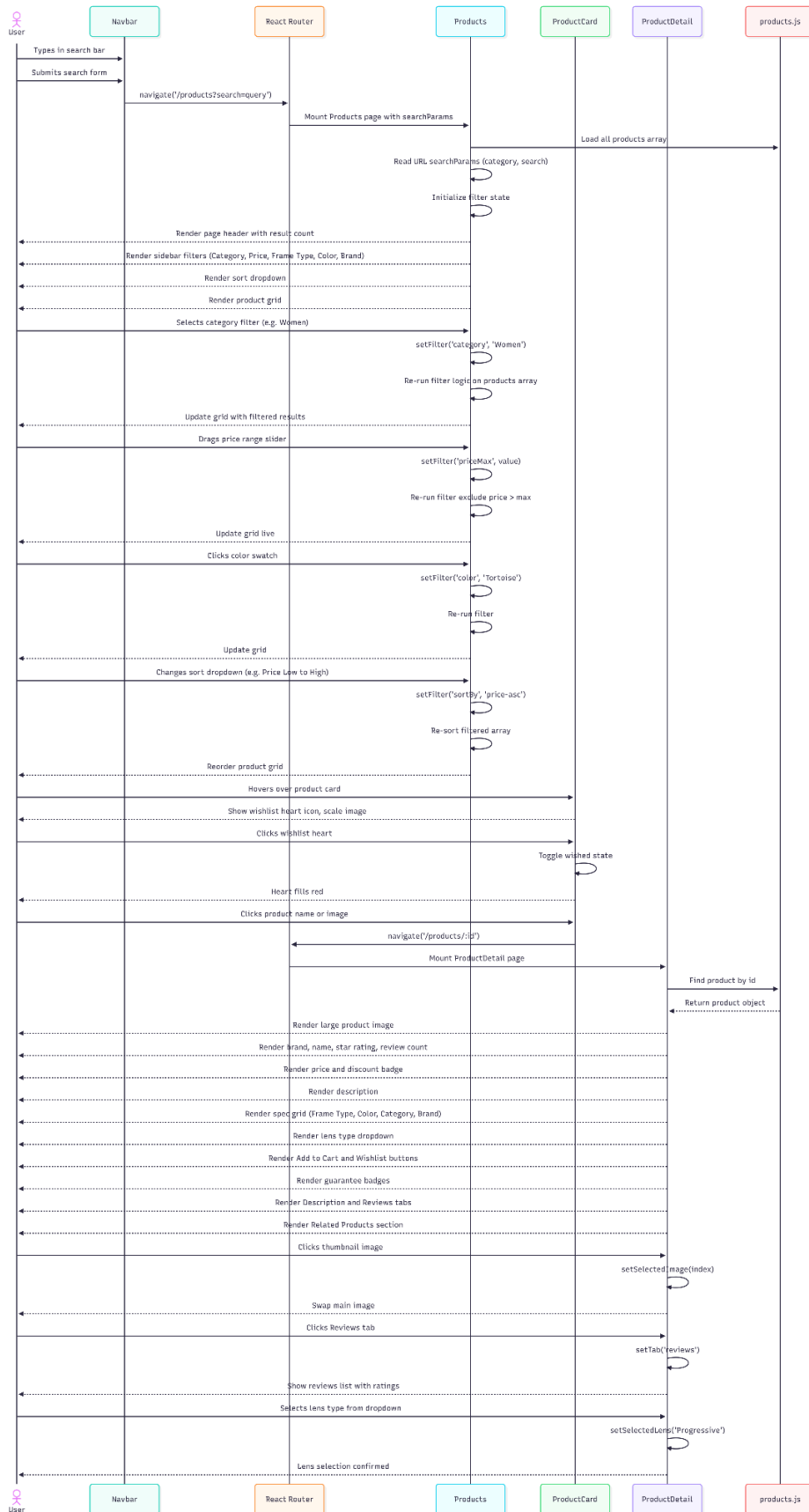


Figure 7: Product Discovery Sequence Diagram

4.4 Cart Management

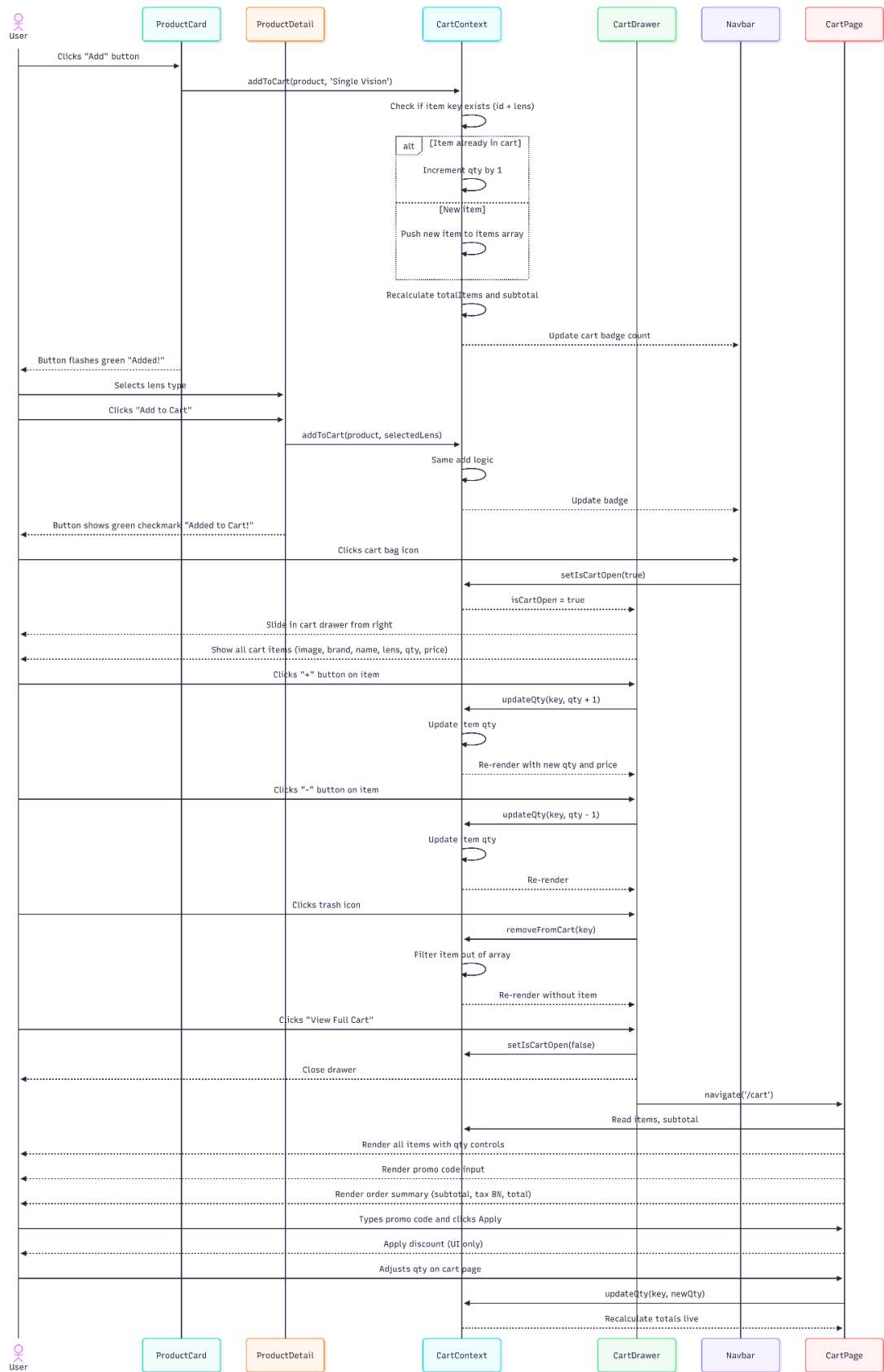


Figure 8: Cart Management Sequence Diagram

4.5 Checkout and Order Confirmation

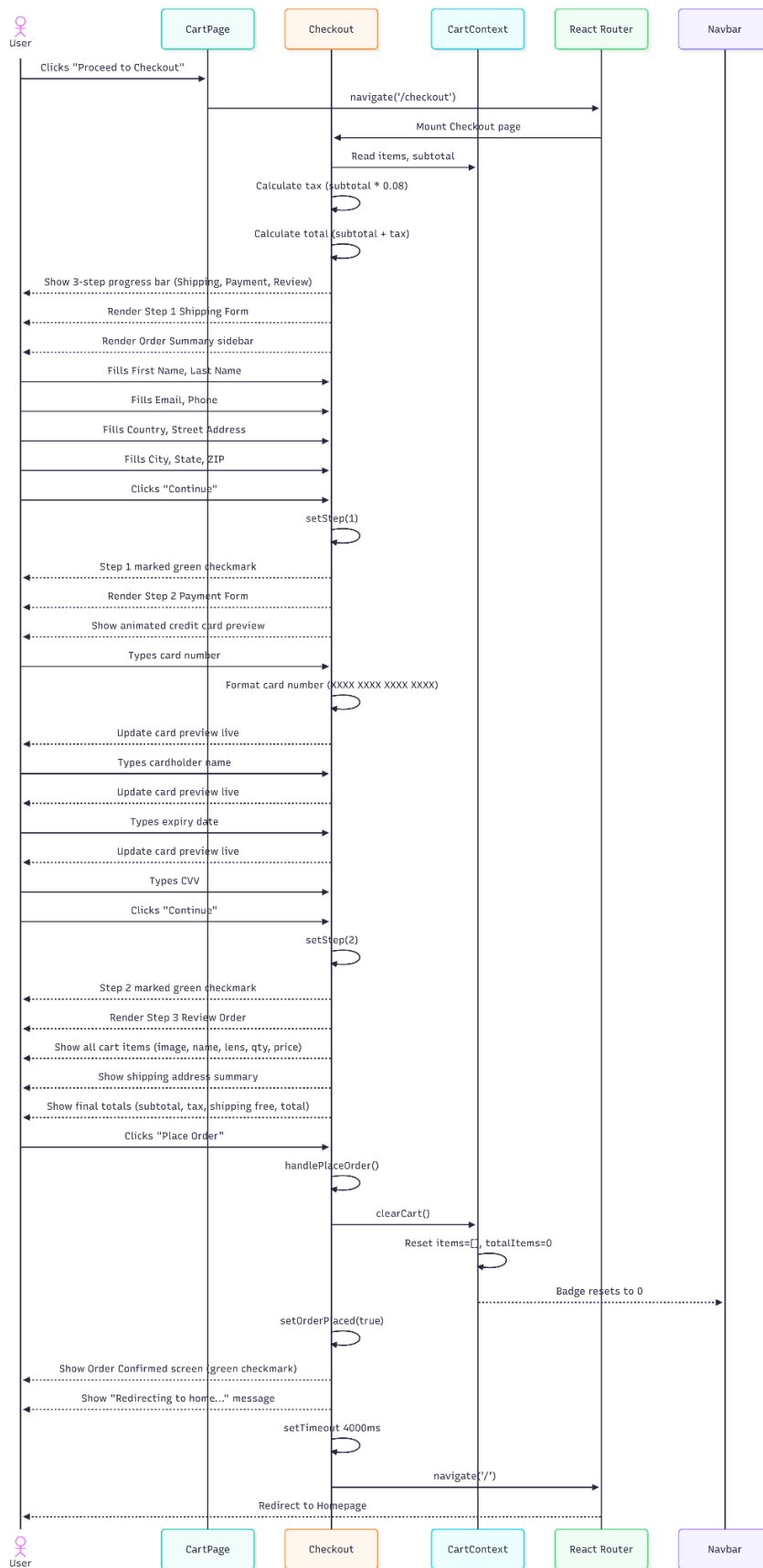


Figure 9: Checkout and Order Confirmation Sequence Diagram

4.6 Appointment Booking

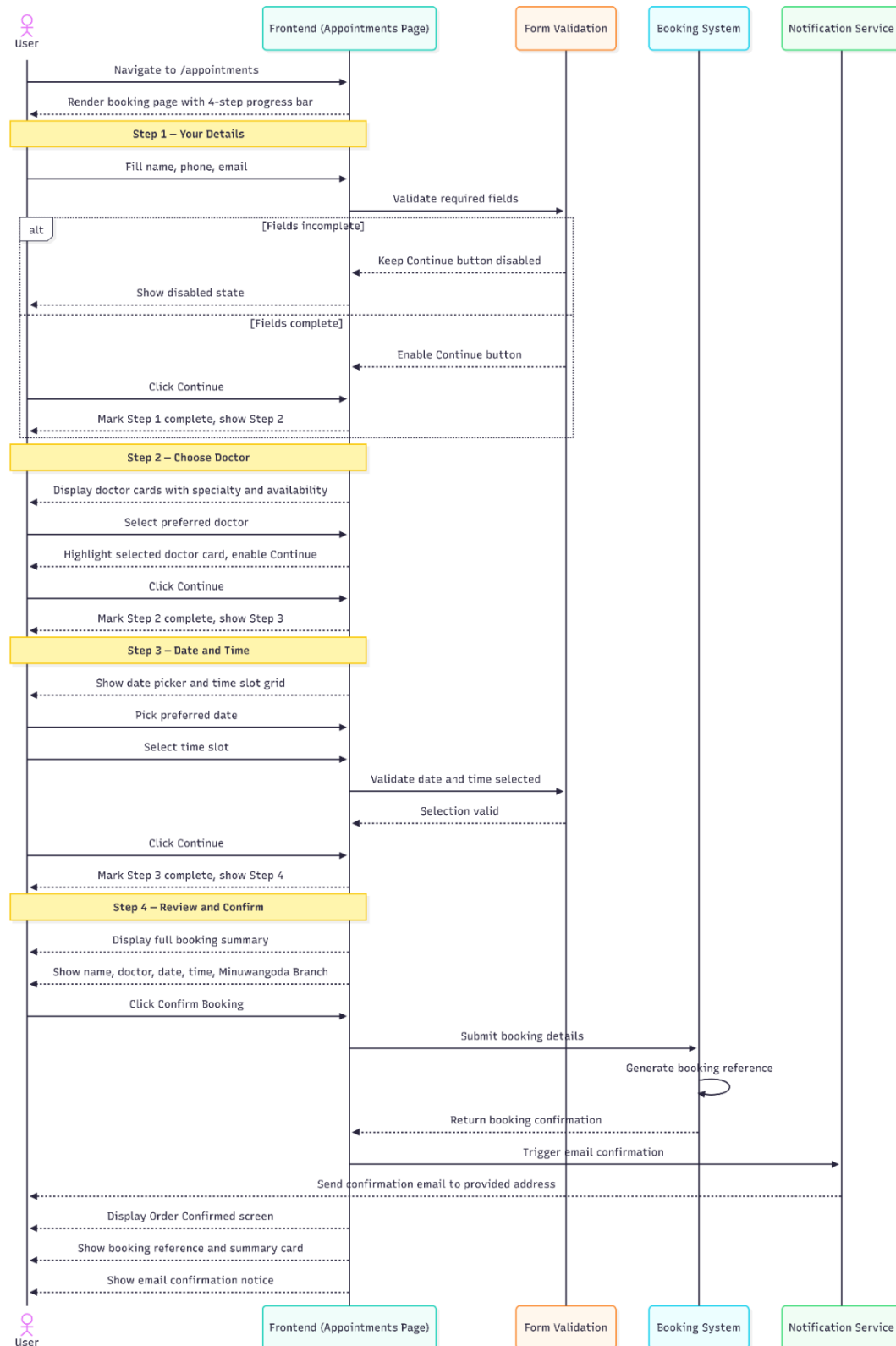


Figure 10: Appointment Booking Sequence Diagram

4.7 Chatbot Interaction

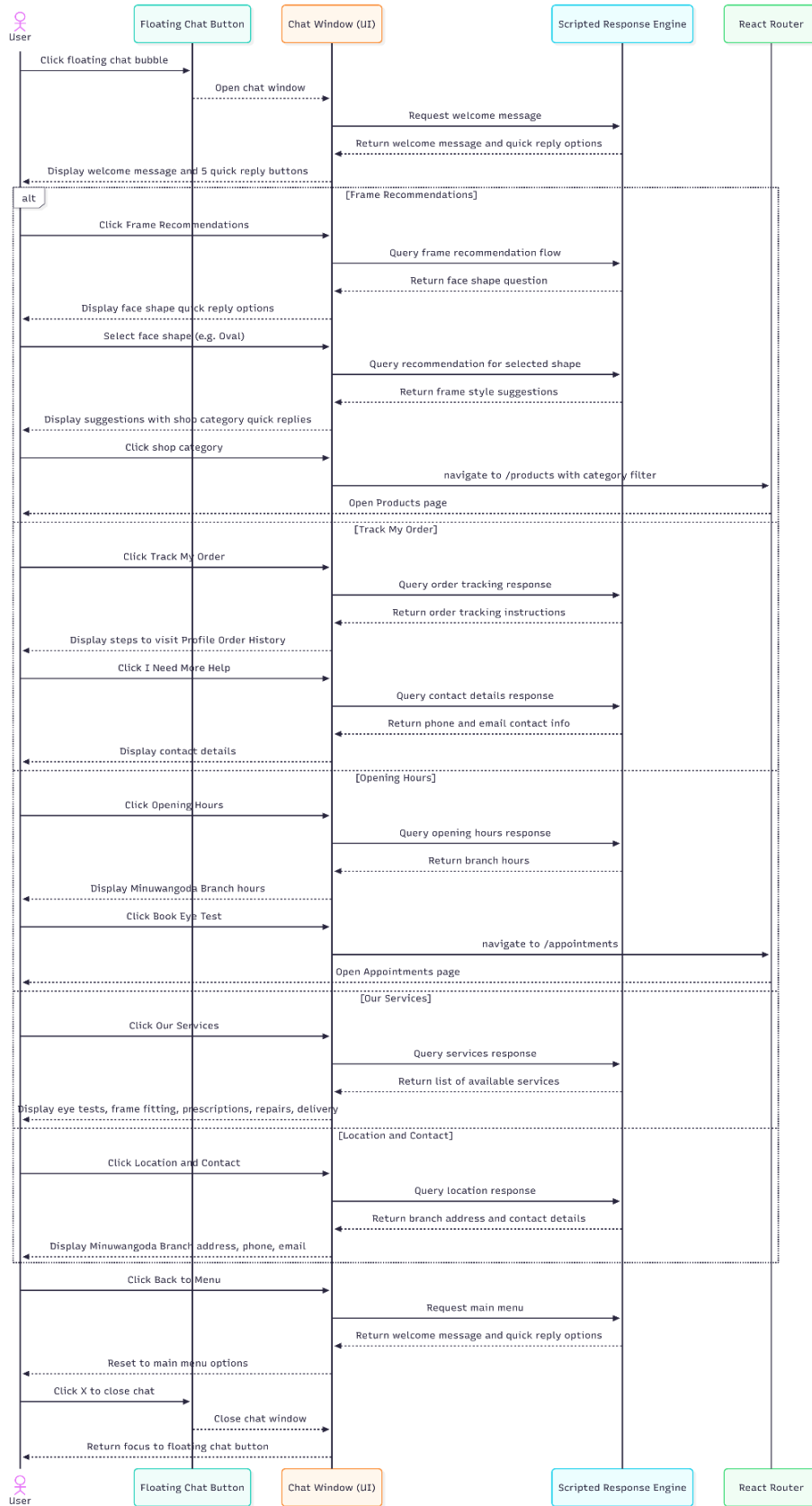


Figure 11: Chatbot Interaction Sequence Diagram

Chapter 5: UI/UX Design

5.1 Screen Mock-ups for Key User Interfaces

Screen mock-ups of the main interfaces are included below, and an interactive version is available through the following link.: [Figma Design](#)

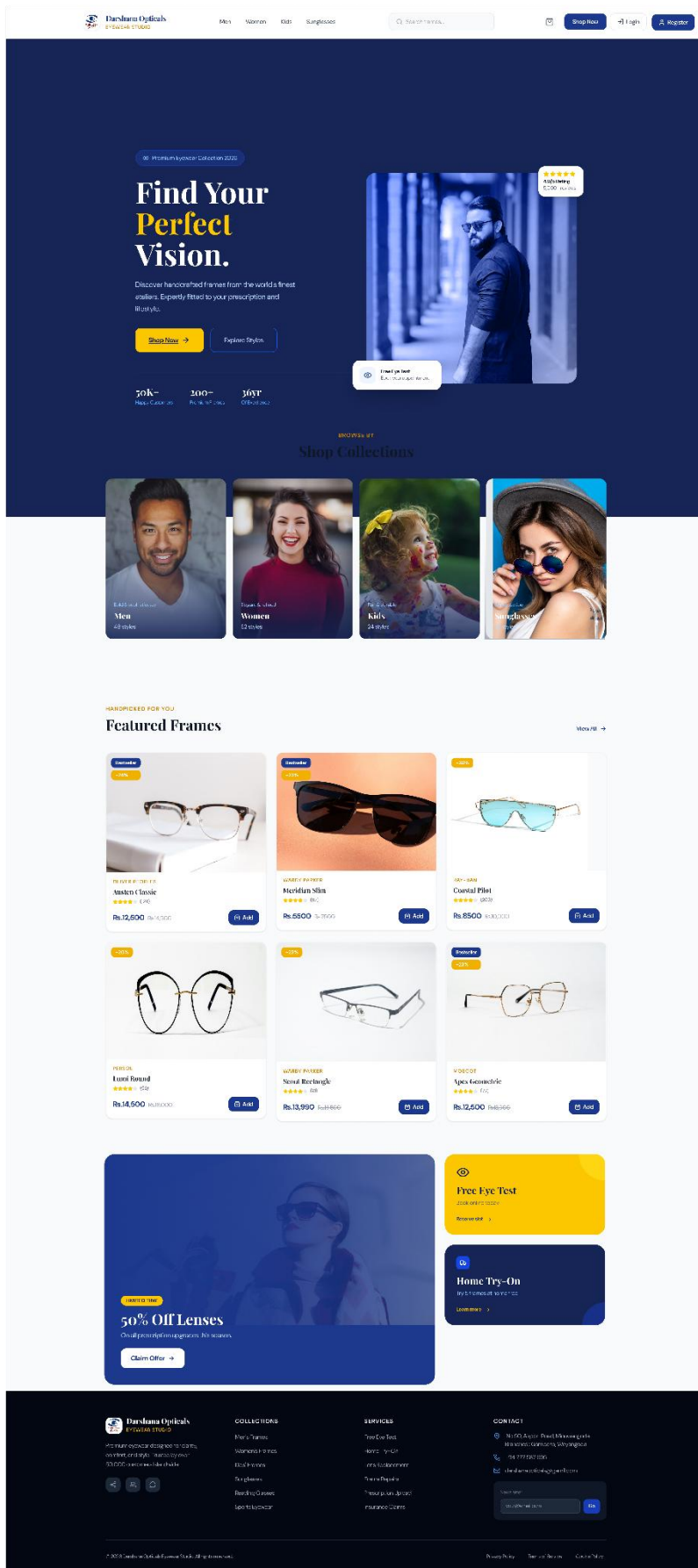


Figure 12: Landing Page

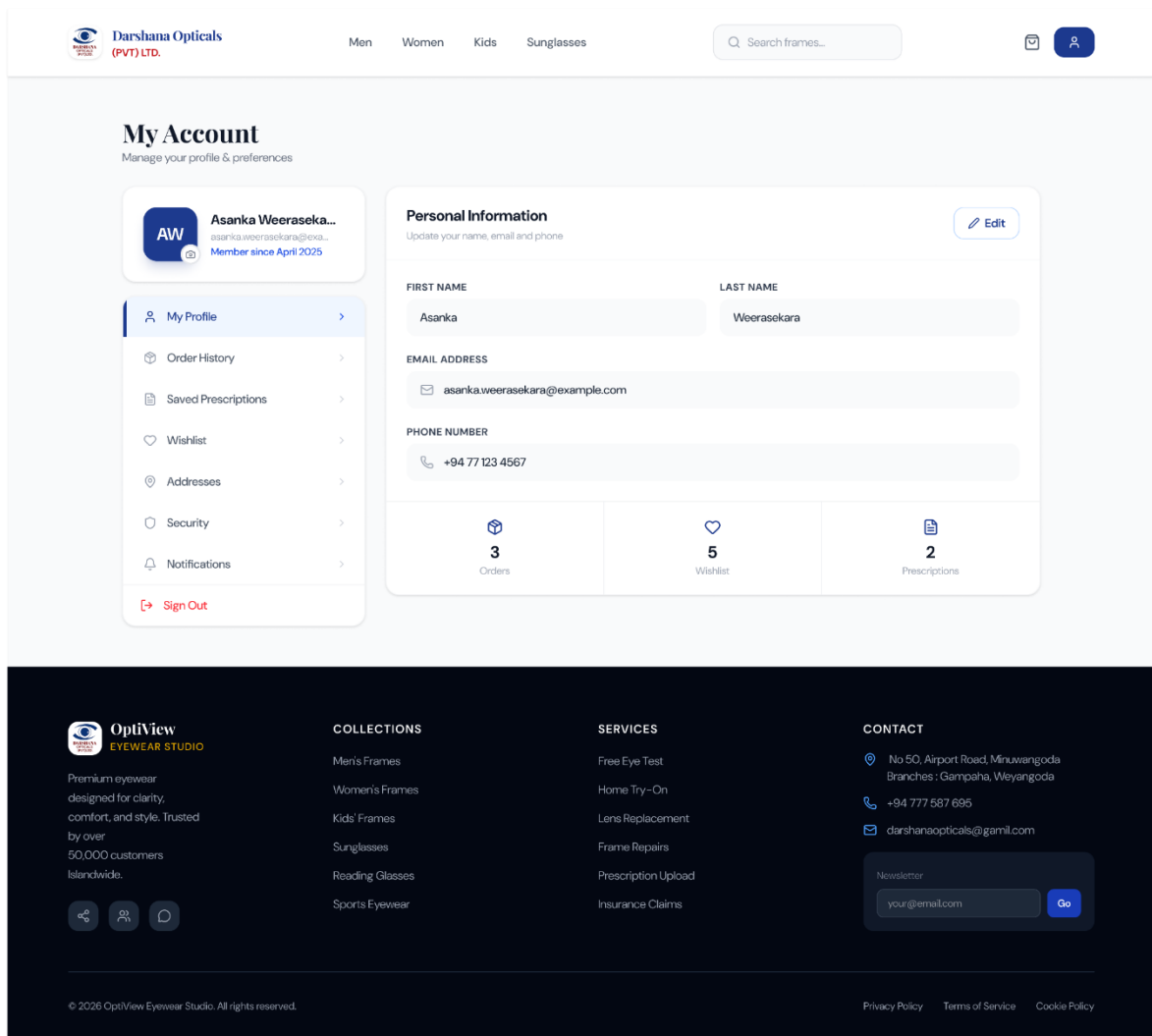
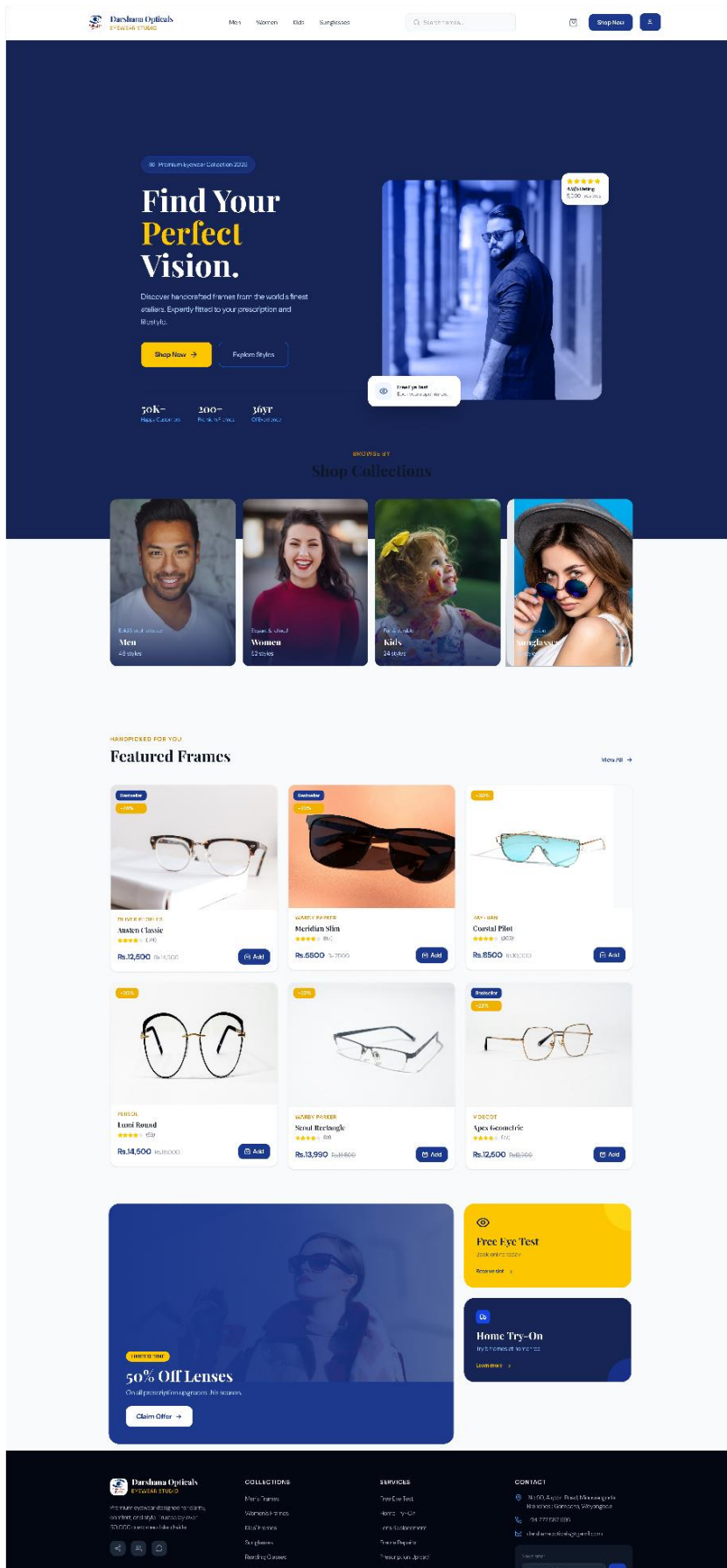


Figure 15: Profile Page



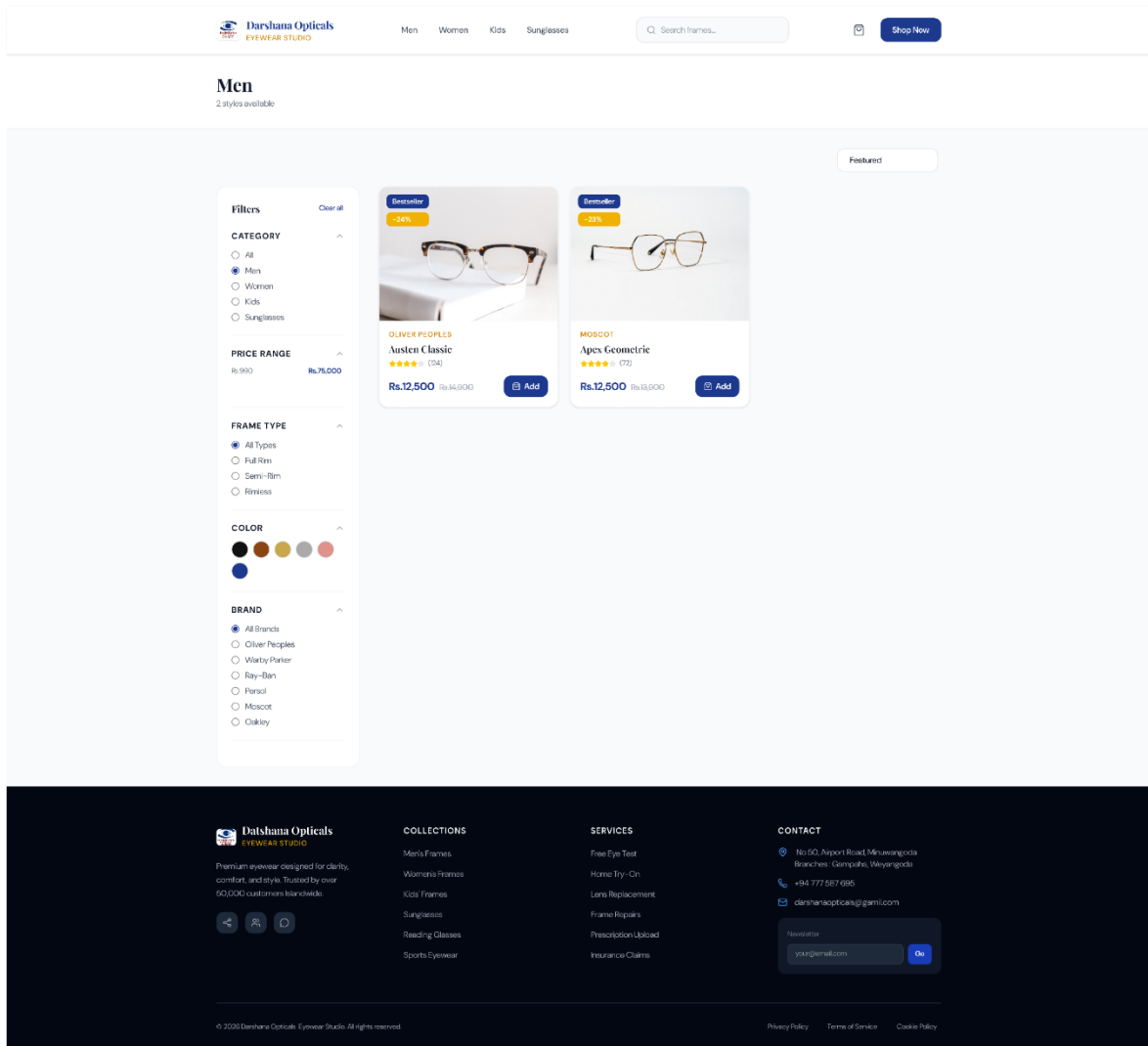


Figure 17: Men's Collection Page

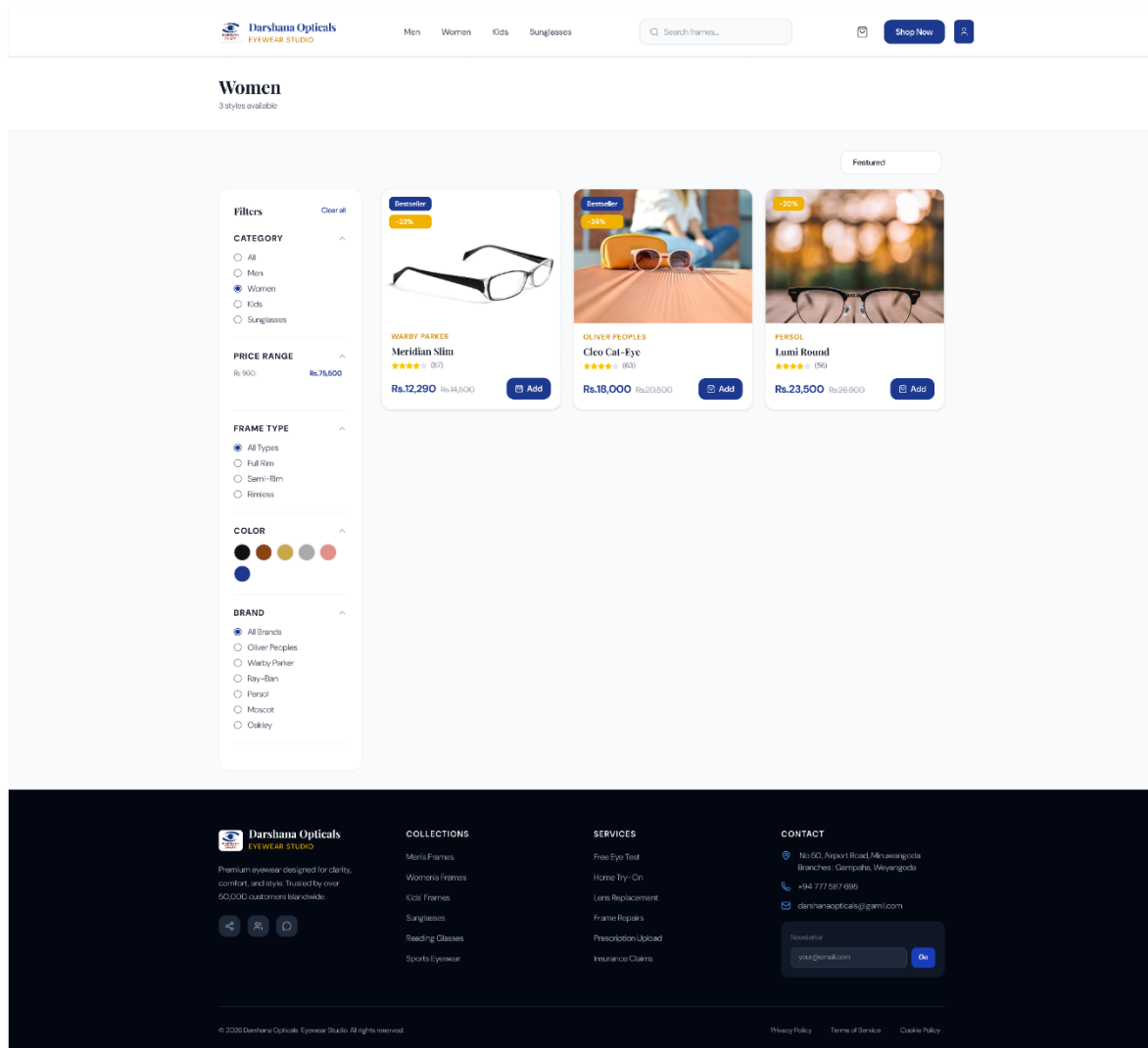


Figure 18: Women's Collection Page

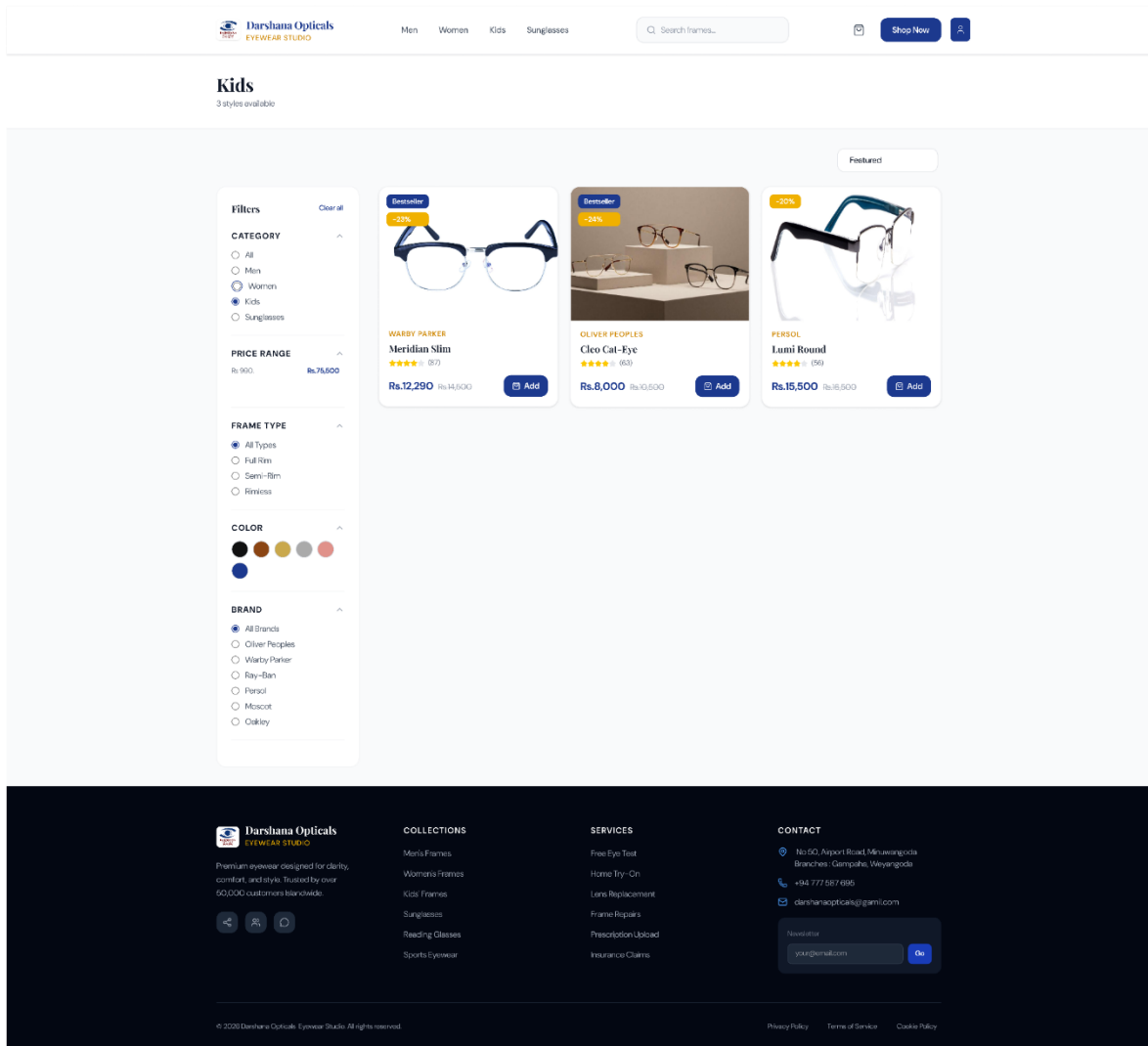


Figure 19: Kids' Collection Page

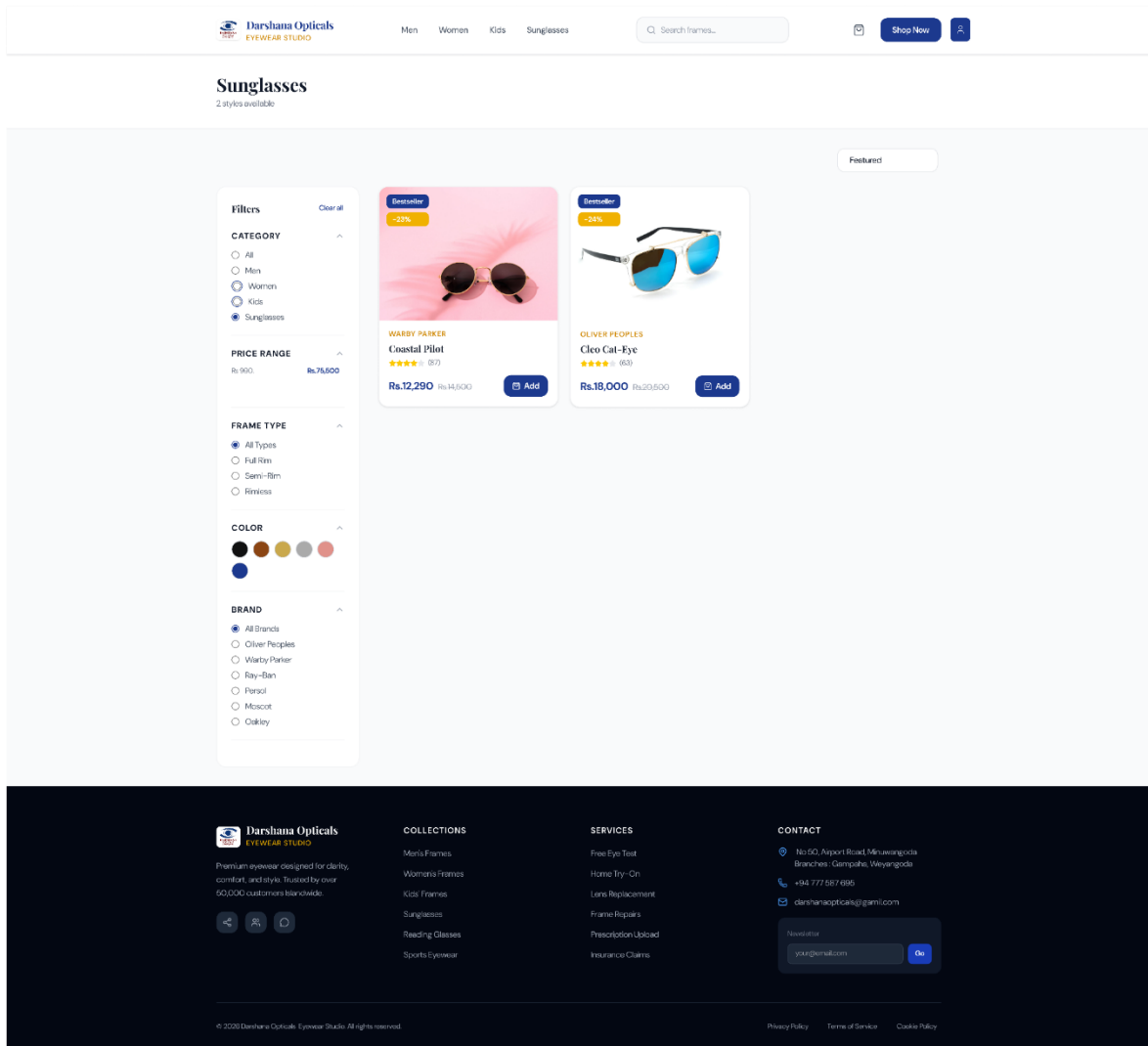


Figure 20: Sunglasses Collection Page

Men

Women

Kids

Sunglasses

Shop Now

Home / Products / Austen Classic

BESTSELLER

OLIVER PEOPLES

Austen Classic

★★★★★

4.8 (224 reviews)

Rs.12,500

Rs.14,900

-24% OFF

Timeless tortoise acetate frames with premium CR-39 lenses. The Austen Classic exudes sophistication with its rounded silhouette and subtle keyhole bridge.

Frame Type

Full Rim

Color

Tortoise

Category

Men

Brand

Oliver Peoples

Lens Type

Select lens type

Add to Cart

Free Shipping

30-Day Returns

2yr Warranty

Description

Reviews (224)

Timeless tortoise acetate frames with premium CR-39 lenses. The Austen Classic exudes sophistication with its rounded silhouette and subtle keyhole bridge.

What's included

- Premium frames with carry case
- Microfiber cleaning cloth
- Certificate of authenticity
- 2-year manufacturer warranty
- Free adjustments at any our store

You May Also Like

Bestseller

22%

MOSCOT

Apex Geometric

★★★★★ (72)

Rs.12,500

Rs.14,000

Add

Premium eyewear designed for clarity, comfort, and style. Trusted by over 50,000 customers worldwide.

←

🔍

🛒

COLLECTIONS

- Men's Frames
- Women's Frames
- Kids' Frames
- Sunglasses
- Reading Glasses
- Sports Eyewear

SERVICES

- Free Eye Test
- Home Try-On
- Lens Replacement
- Frame Repairs
- Prescription Upload
- Insurance Claims

CONTACT

No 50, Airport Road, Minuwangoda

Branches - Gampaha, Weyangoda

+94 777 587 895

darshanoopticals@gmail.com

Newsletter

Go

© 2025 Darshana Opticals Eyewear Studio. All rights reserved.

Privacy Policy

Terms of Service

Cookie Policy

Figure 21: Product Information Page

30

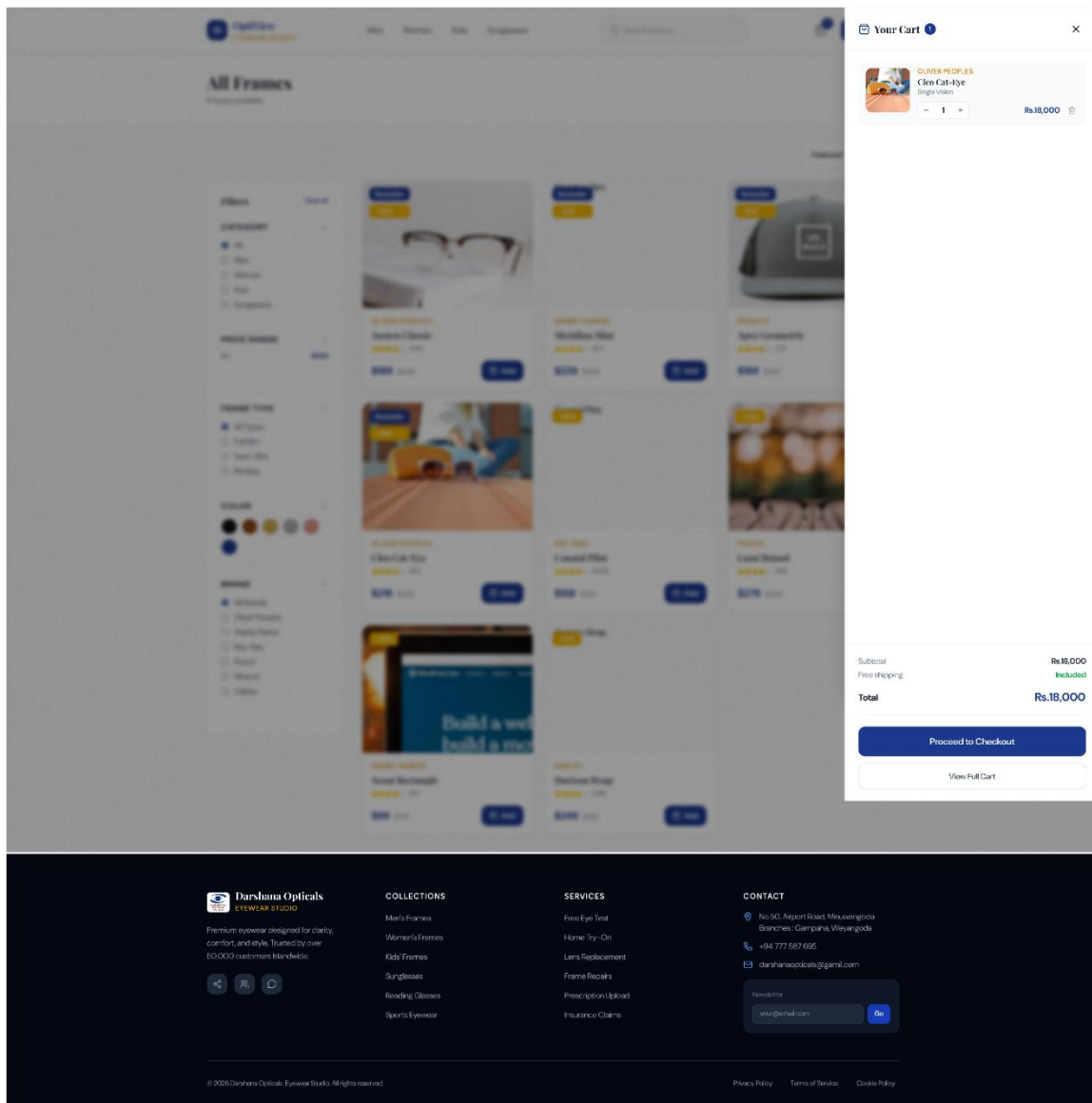


Figure 22: Cart Drawer



[Men](#)
[Women](#)
[Kids](#)
[Sunglasses](#)


[Shop Now](#)

1 Shipping

2 Payment

3 Review

Shipping Information

FIRST NAME

LAST NAME

EMAIL

PHONE

STREET ADDRESS

CITY

STATE

ZIP

Back to Cart

Continue

Order Summary

Clear Cat-Eye x 1	Rs.18,000
Subtotal	Rs.18,000
Tax	Rs.0
Shipping	Free
Total	Rs.18,000



Premium eyewear designed for clarity, comfort, and style. Trusted by over 50,000 customers worldwide.





COLLECTIONS

[Men's Frames](#)
[Women's Frames](#)
[Kids' Frames](#)
[Sunglasses](#)
[Reading Glasses](#)
[Sports Eyewear](#)

SERVICES

[Free Eye Test](#)
[Home Try-On](#)
[Lens Replacement](#)
[Frame Repairs](#)
[Prescription Upload](#)
[Insurance Claims](#)

CONTACT

No 50, Airport Road, Miruwangoda
Branches : Gampaha, Welisara
+94 777 557 695
darshanapopticals@gmail.com

© 2023 Darshana Opticals Eyewear Studio. All rights reserved.

[Privacy Policy](#)
[Terms of Service](#)
[Cookie Policy](#)

Figure 23: Shipping Information Page



[Men](#)
[Women](#)
[Kids](#)
[Sunglasses](#)



1

[Shop Now](#)

Shipping

Payment

Review

Payment Details

Your payment info is encrypted and secure



4249 5779 9909 7775

Card Holder

ASANKA WEERASEKARA

Expires

10/28

CARD NUMBER

CARDHOLDER NAME

EXPIRY DATE

CVV

← Back

Continue →

Order Summary

Clear Cat - Eye x 1	Rs.18,000
Subtotal	Rs.18,000
Tax	Rs.0
Shipping	Free
Total	Rs.18,000



Premium eyewear designed for clarity, comfort, and style. Trusted by over 50,000 customers worldwide.



COLLECTIONS

- Men's Frames
- Women's Frames
- Kids' Frames
- Sunglasses
- Reading Glasses
- Sports Eyewear

SERVICES

- Free Eye Test
- Home Try-On
- Lens Replacement
- Frame Repairs
- Prescription Upload
- Insurance Claims

CONTACT

No 50, Airport Road, Miruwangoda
Branches : Gampaha, Weyangoda

+94 777 557 695
darshanapopticals@gmail.com

© 2028 Darshana Opticals Eyewear Studio. All rights reserved.

[Privacy Policy](#)
[Terms of Service](#)
[Cookie Policy](#)

Figure 24: Payment Details Page

33

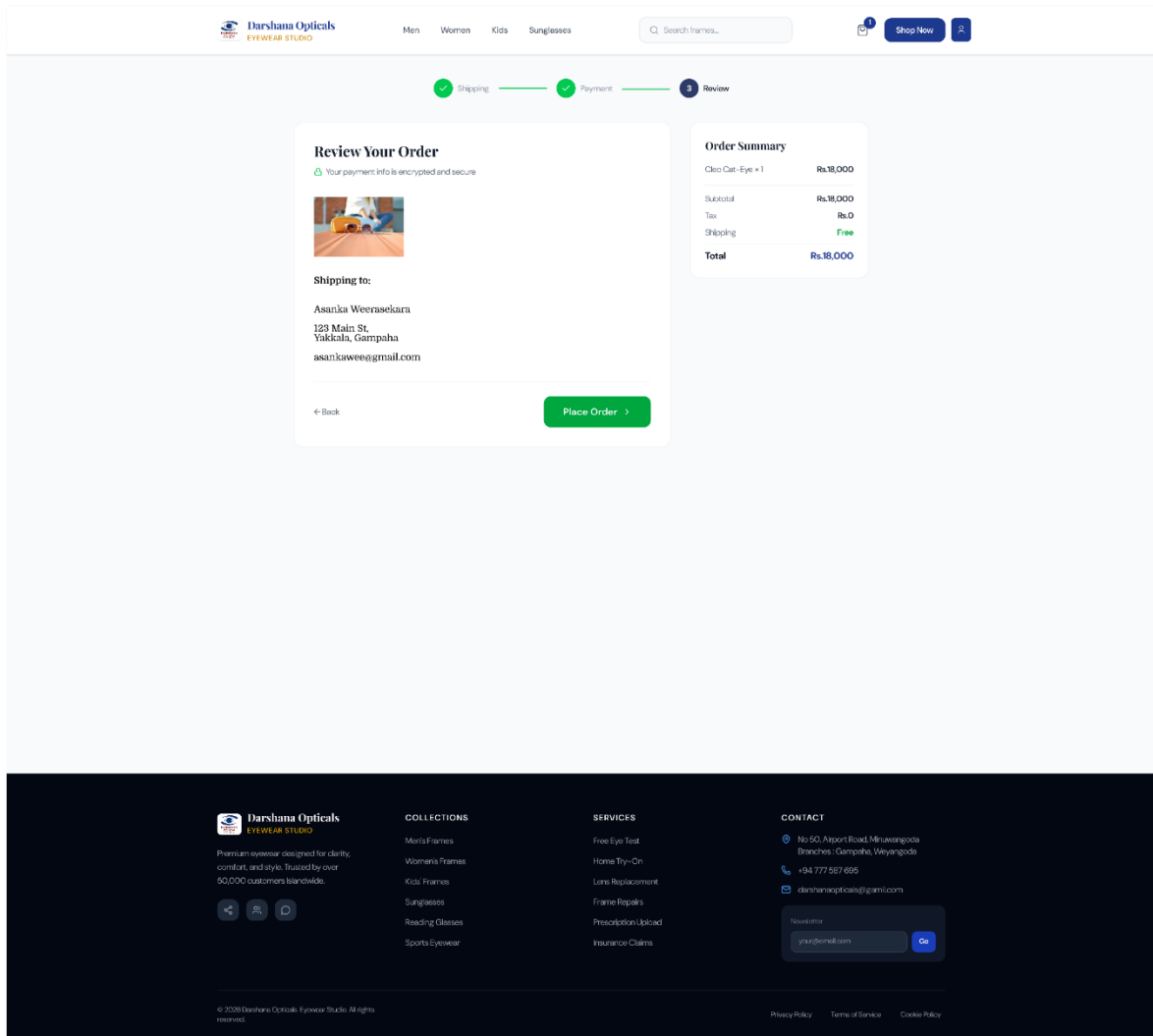


Figure 25: Order Review Page

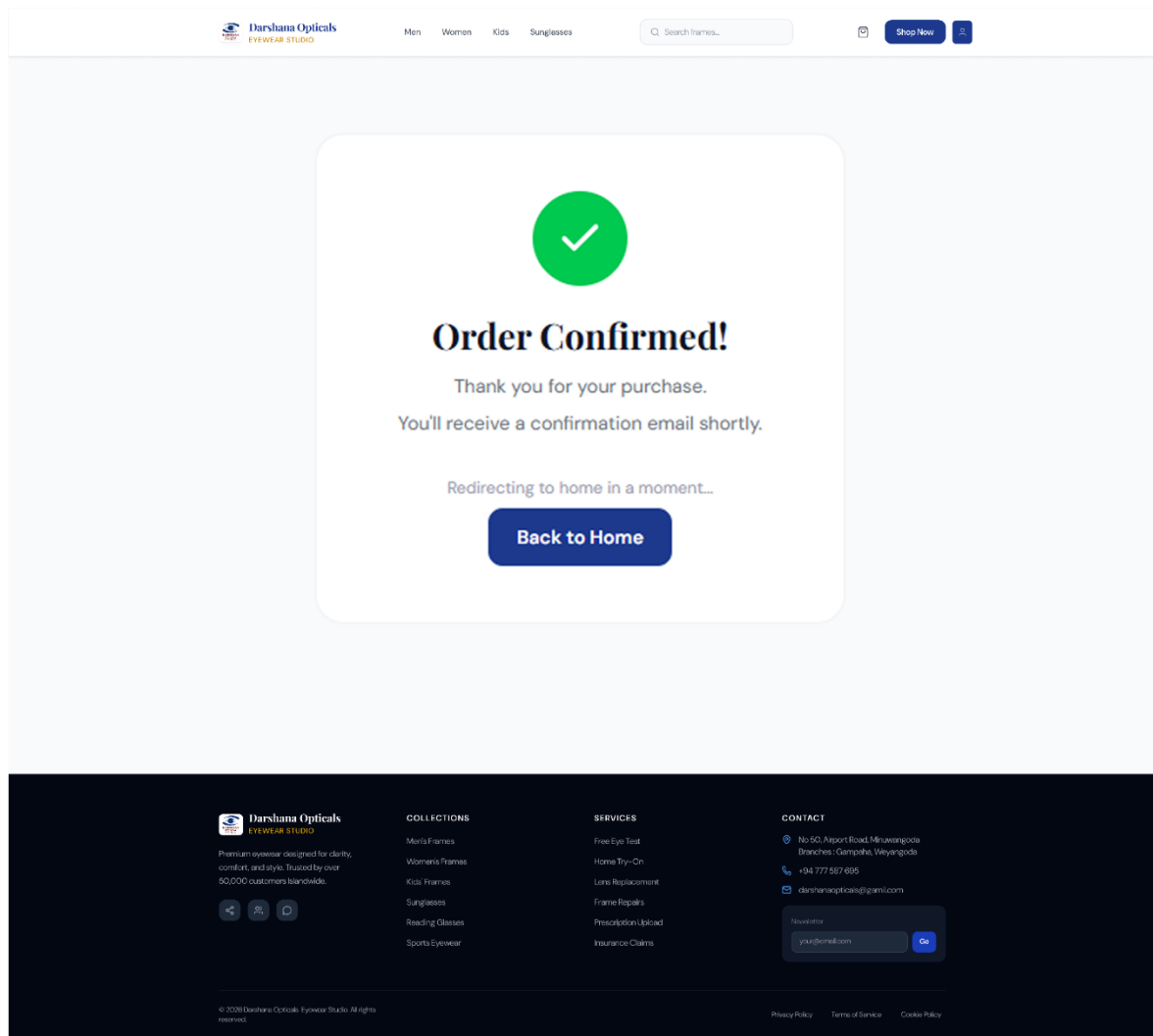


Figure 26: Order Confirmation Page

Men
Women
Kids
Sunglasses

Eye Test — Minuwangoda Branch

Book Your Eye Test

Schedule a professional eye examination with our certified optometrists.

1
2
3
4

Your Details
Choose Doctor
Date & Time
Confirm

Your details

FULL NAME *

PHONE NUMBER *

EMAIL ADDRESS *

Appointment Location

Darshana Optical's — Minuwangoda Branch

Continue

Premium eyewear designed for clarity, comfort, and style. Trusted by over 50,000 customers worldwide.

COLLECTIONS

- Men's Frames
- Women's Frames
- Kids Frames
- Sunglasses
- Reading Glasses
- Sports Eyewear

SERVICES

- Free Eye Test
- Home Try-On
- Lens Replacement
- Frame Repairs
- Prescription Upload
- Insurance Claims

CONTACT

No 50, Airport Road, Minuwangoda
Branches : Gampaha, Weyangoda
+94 777 667 695
darshanaopticals@gmail.com

Newsletter
Go

© 2025 Darshana Optical's Eyewear Studio. All rights reserved.

[Privacy Policy](#)
[Terms of Service](#)
[Cookie Policy](#)

Figure 27: Patient Details Page

36

Men
Women
Kids
Sunglasses

Eye Test — Minuwangoda Branch

Book Your Eye Test

Schedule a professional eye examination with our certified optometrists.

1

2

3

4

1

2

3

4

1

2

3

4

1

2

3

4

Choose your doctor

FS

Dr. Samantha Fernando

Optometrist

Available Mon, Wed, Fri

PR

Dr. Ruwan Perera

Optometrist

Available Tue, Thu, Sat

JN

Dr. Nirmali Jayawardena

Optometrist

Available Mon, Tue, Thu

← Back

Continue →

Premium eyewear designed for clarity, comfort, and style. Trusted by over 50,000 customers islandwide.

COLLECTIONS

- Men's Frames
- Women's Frames
- Kids Frames
- Sunglasses
- Reading Glasses
- Sports Eyewear

SERVICES

- Free Eye Test
- Home Try-On
- Lens Replacement
- Frame Repairs
- Prescription Upload
- Insurance Claims

CONTACT

No 50, Airport Road, Minuwangoda
Branches - Gampaha, Weyangoda
+94 777 667 695
darshanaopticals@gmail.com

© 2026 Darshana Optical's Eyewear Studio. All rights reserved.

[Privacy Policy](#)
[Terms of Service](#)
[Cookie Policy](#)

Figure 28: Doctor Selection Page

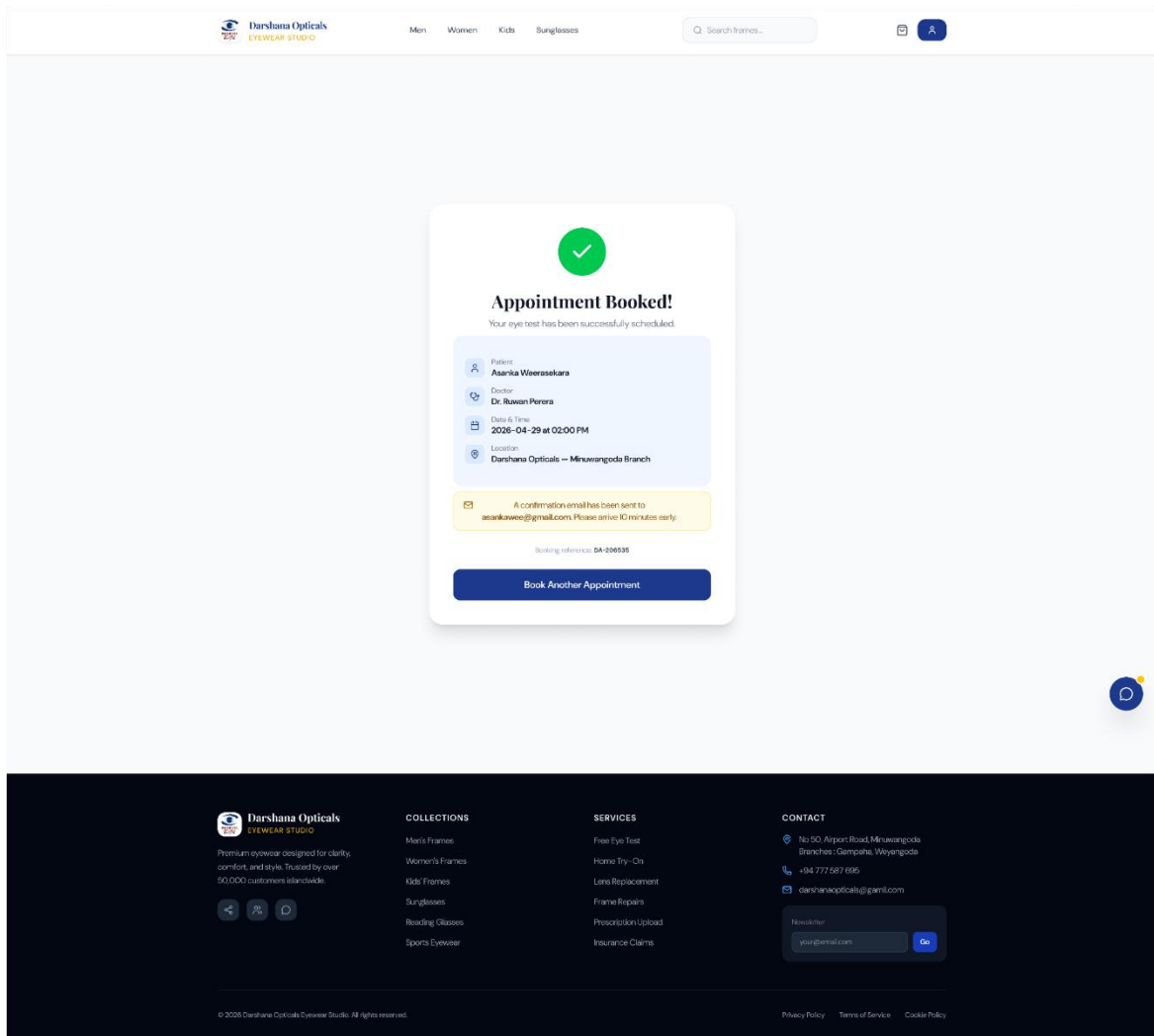


Figure 31: Appointment Confirmation Page

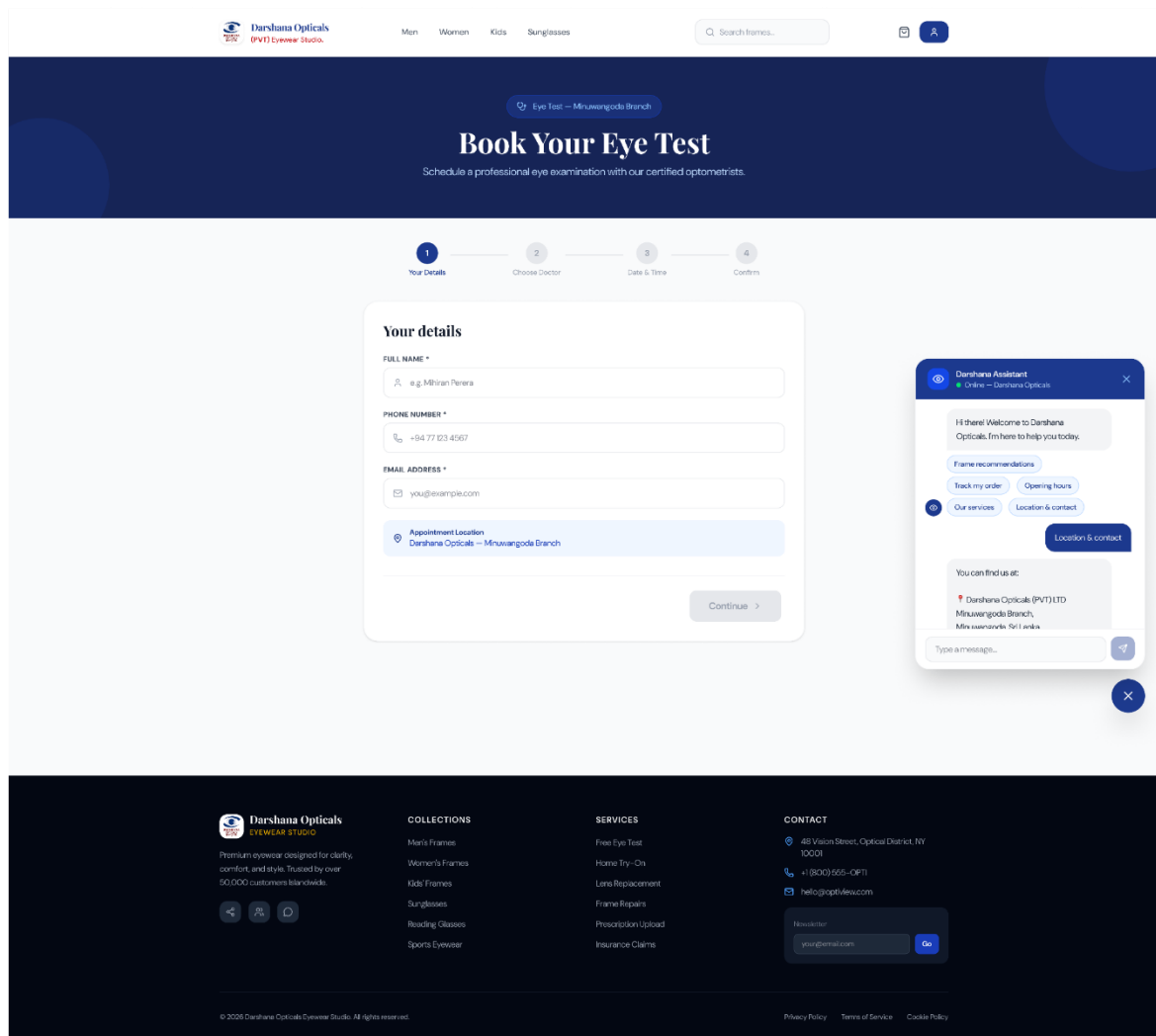


Figure 32: Chatbot Widget

5.2 User flow / Navigation Diagrams

1. Role-based user flow

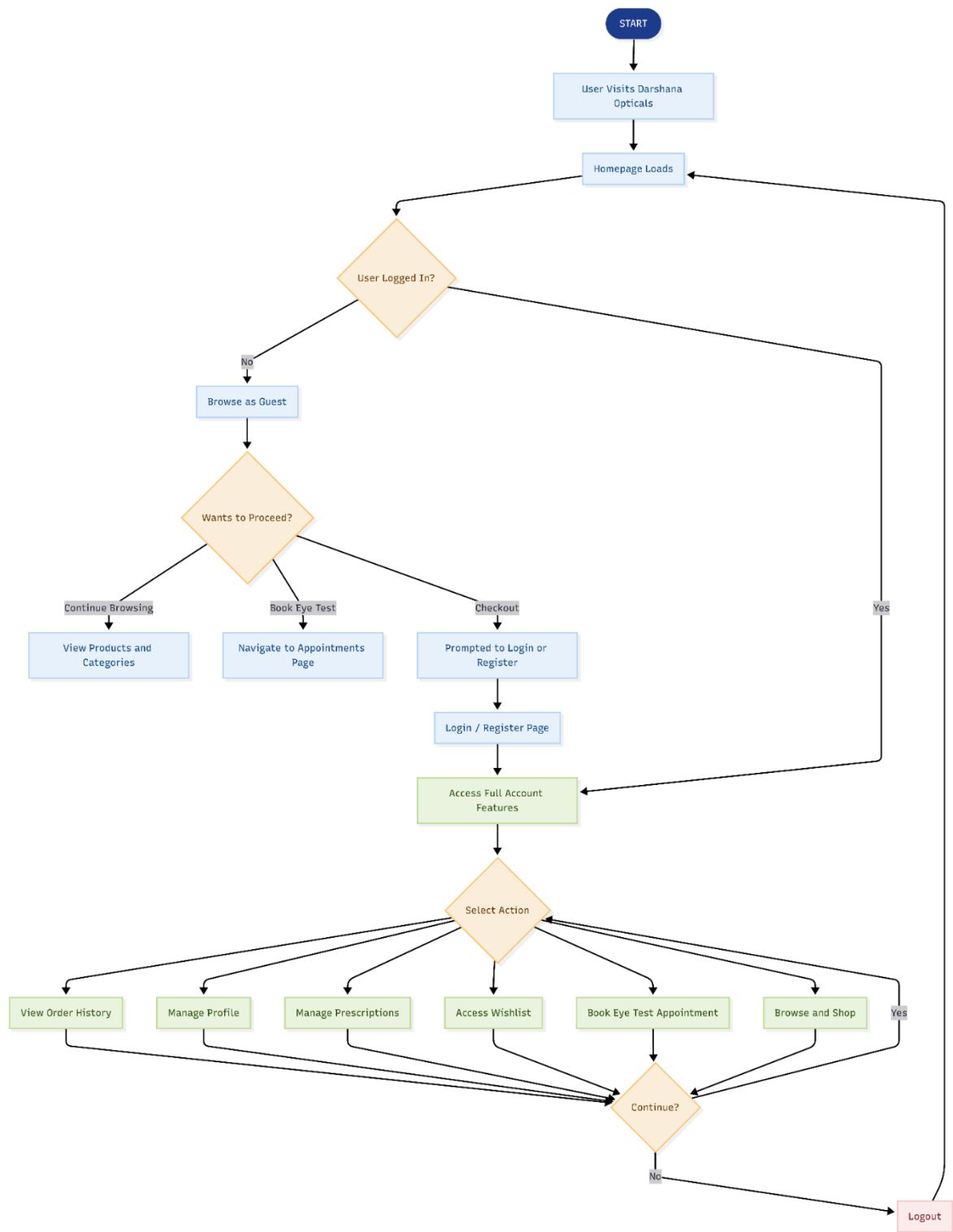


Figure 33: Role-Based User Flow

2. Browse and product discovery flow

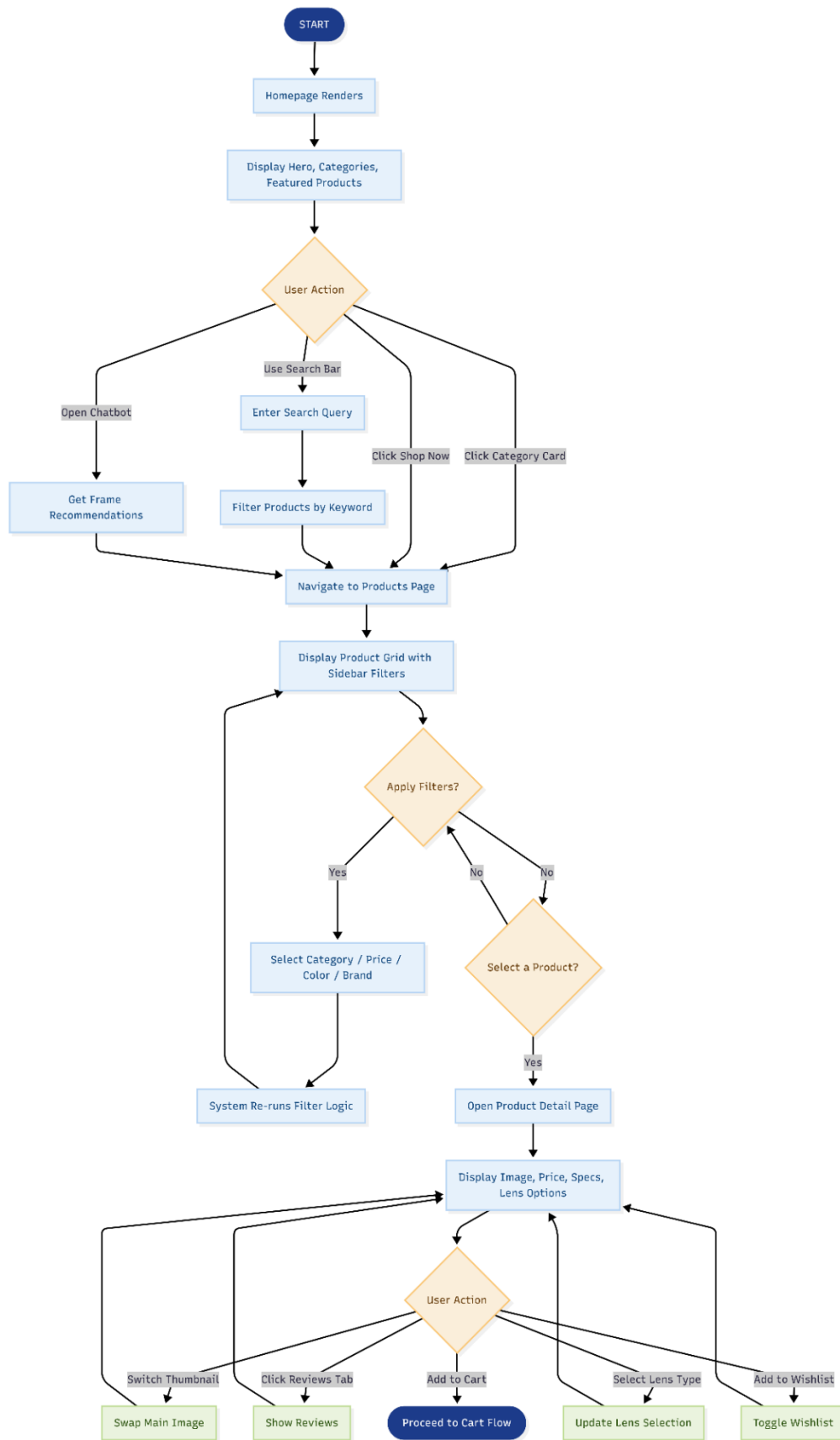


Figure 34: Browse and Product Discovery Flow

3. Cart management flow

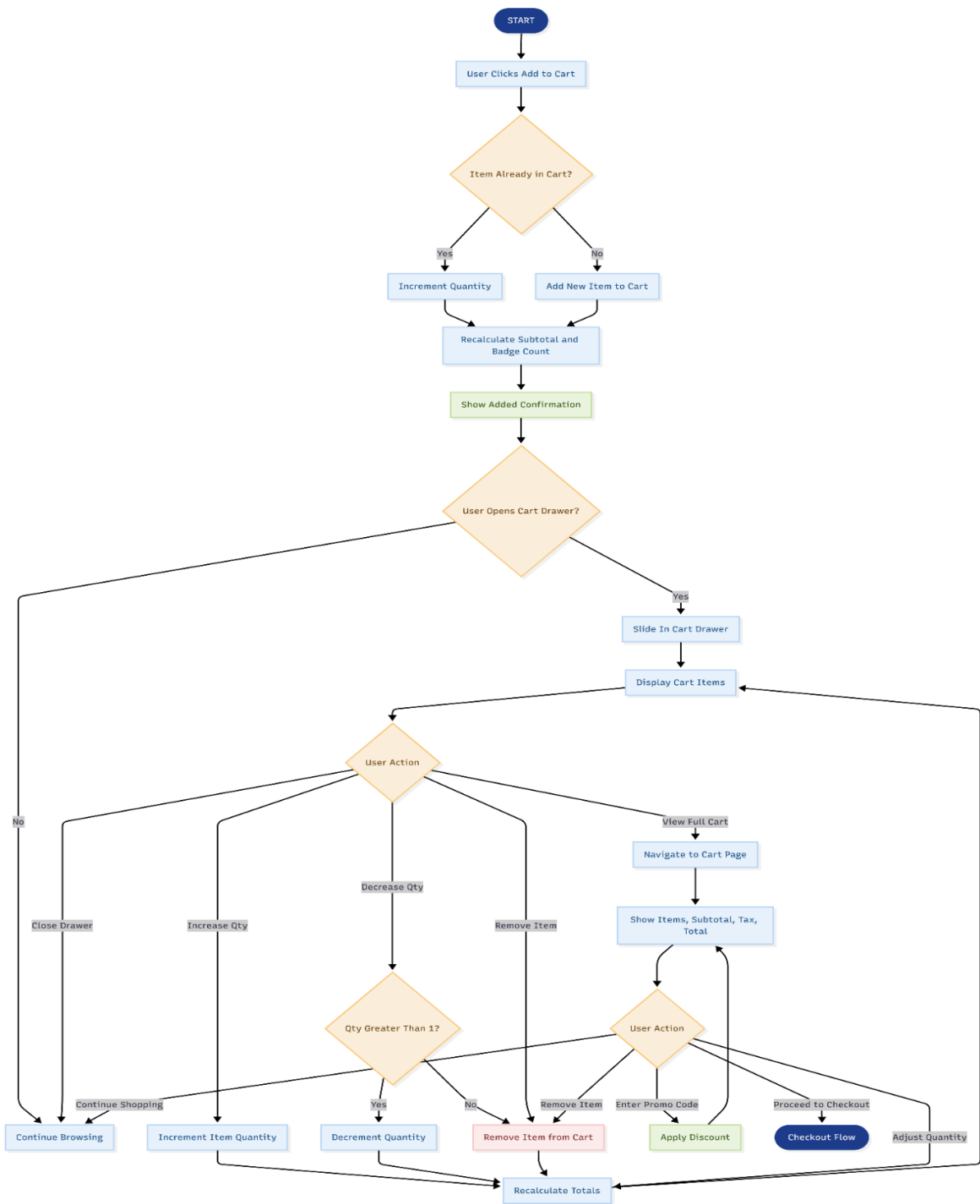


Figure 35: Cart Management Flow

4. Checkout and order confirmation flow

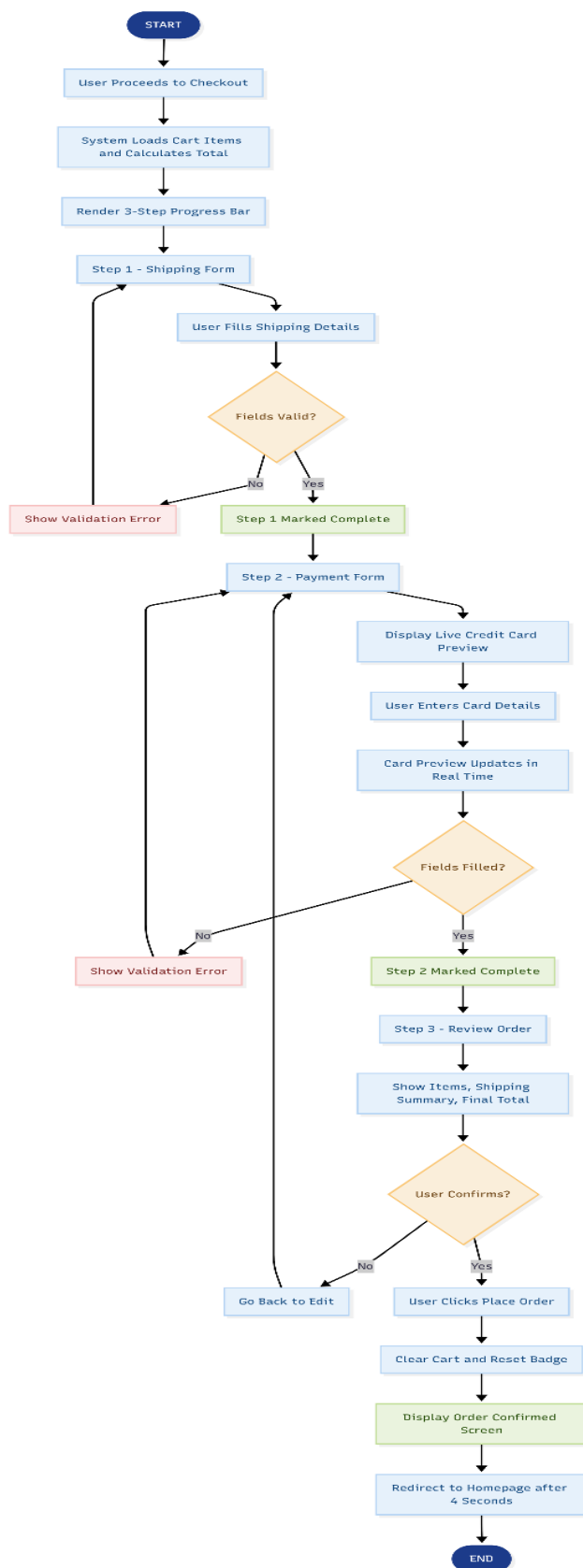


Figure 36: Checkout and Order Confirmation Flow

5. User profile management flow

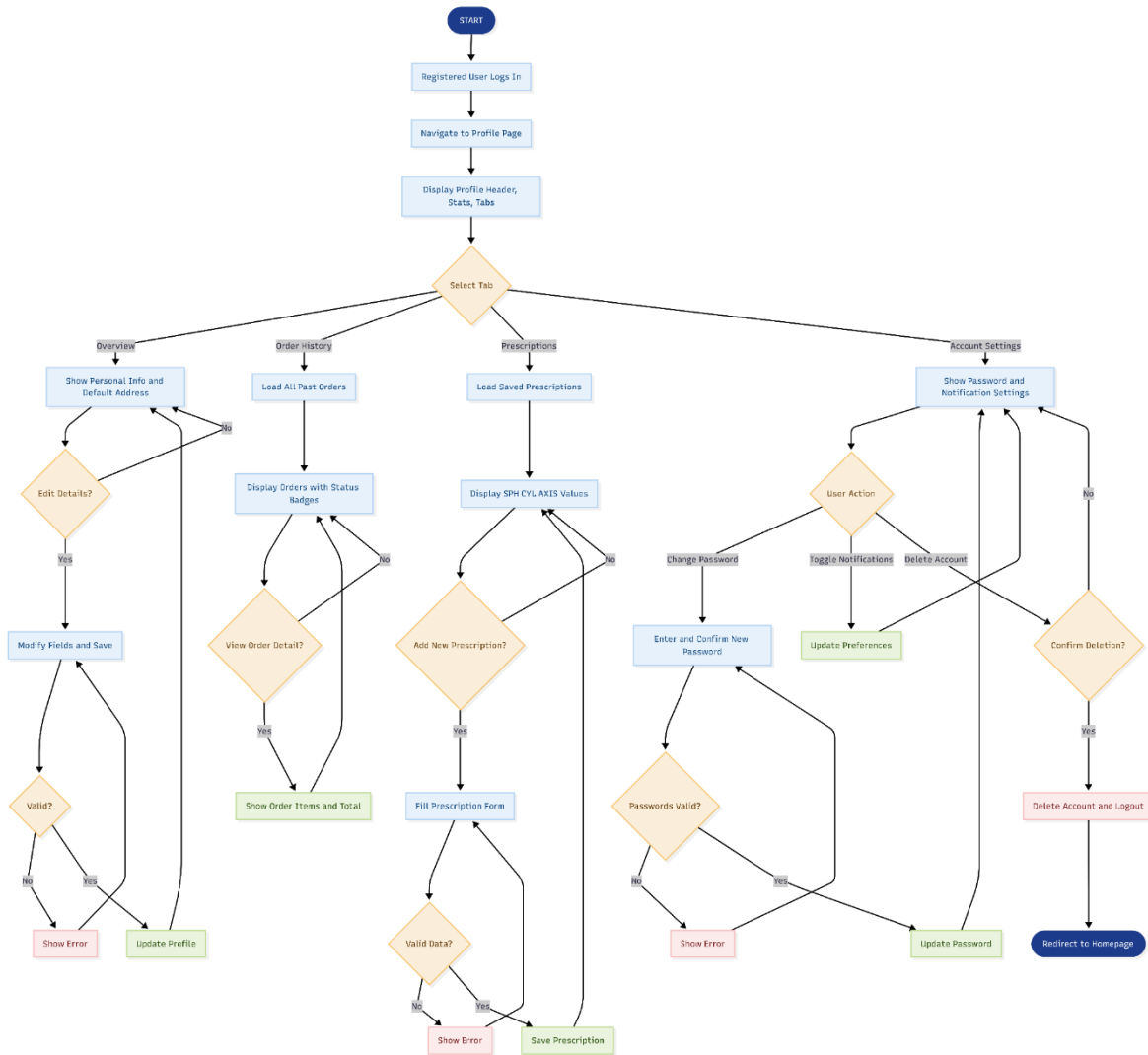


Figure 37: User Profile Management Flow

6. Authentication flow

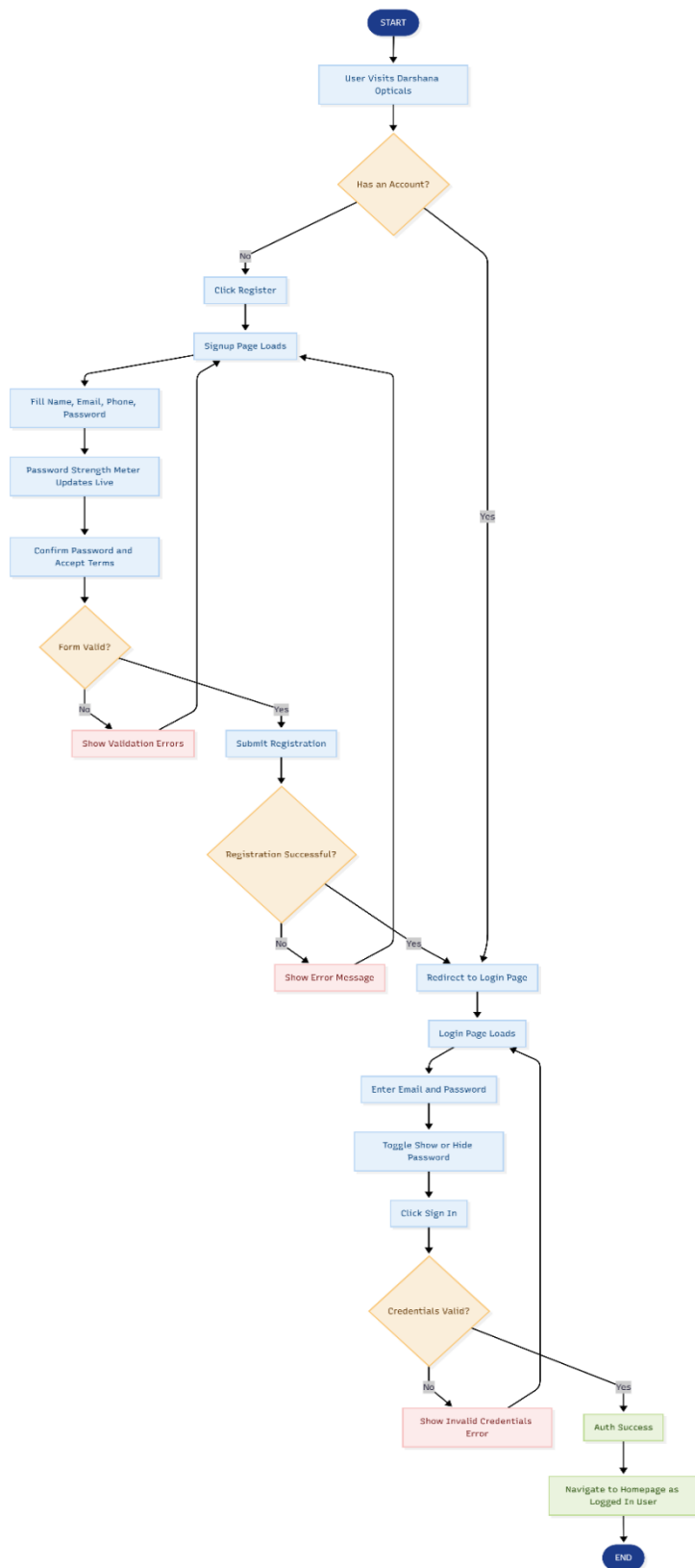


Figure 38: Authentication Flow

7. Appointment booking flow

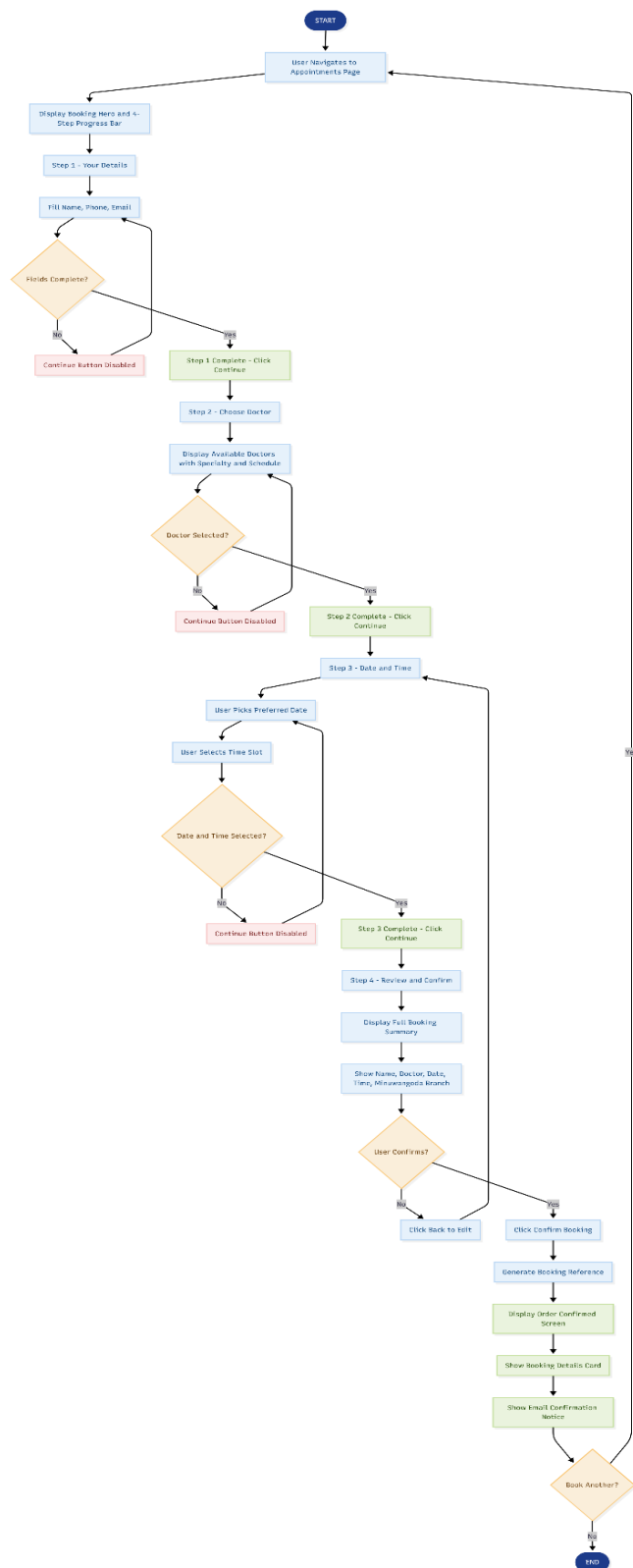


Figure 39: Appointment Booking Flow

8. Chatbot interaction flow

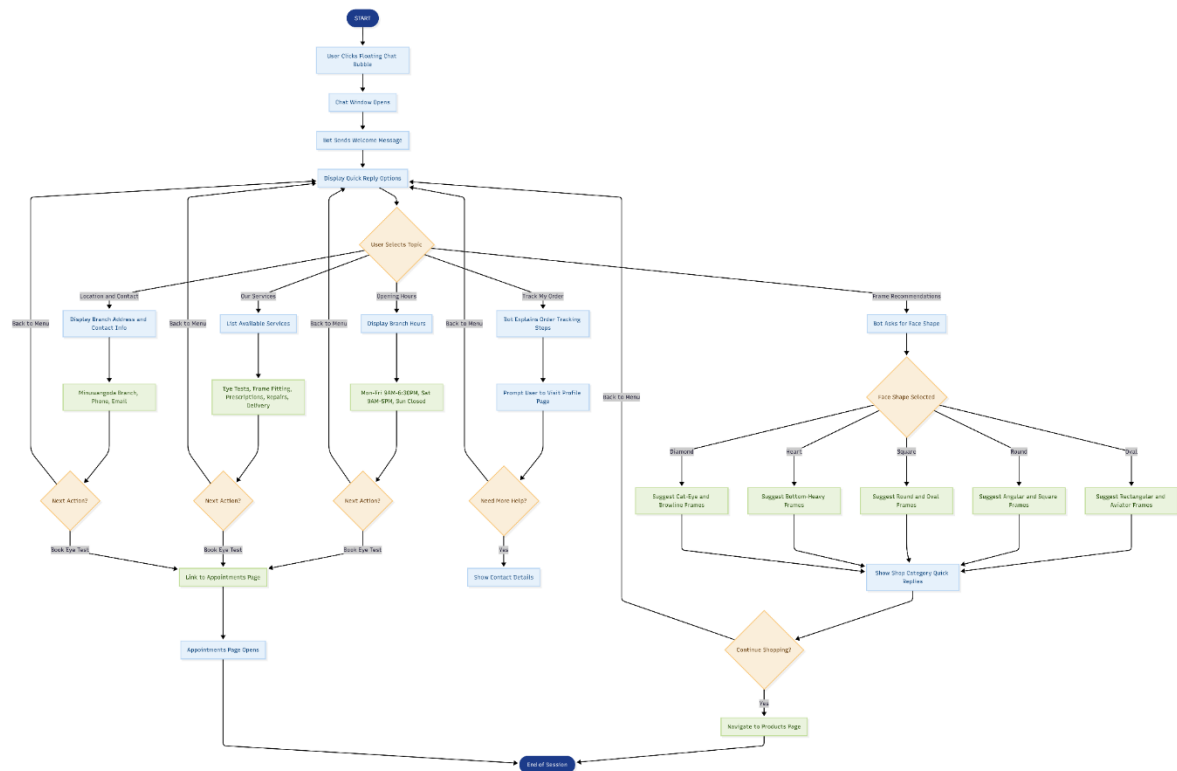


Figure 40: Chatbot Interaction Flow

5.3 Accessibility Considerations

Darshana Opticals (PVT) LTD.

The Darshana Opticals web application is designed with accessibility as a fundamental requirement, targeting conformance with the Web Content Accessibility Guidelines (WCAG) 2.1 at Level AA. These considerations apply across all user-facing pages and components of the system, including the Homepage, Product Listing, Product Detail, Cart, Checkout, Login, Signup, User Profile, Appointment Booking, and the Chatbot interface.

1. Perceivable

All product images displayed across the Homepage featured grid, Product Listing page, and Product Detail page include descriptive alternative text that communicates the product name, brand, and frame style to screen reader users. For example, an image of the Austen Classic tortoise frame by Oliver Peoples would carry alt text describing those exact details rather than a generic label.

Color is never used as the sole means of conveying information throughout the system. Order status badges in the Profile Order History tab, such as Delivered, Processing, and Pending, use both a colored background and a visible text label simultaneously. Discount badges on

product cards display the percentage value as text alongside the amber-colored label. The password strength meter on the Signup page communicates strength through both a color-coded progress bar and a text label Weak, Fair, Good, or Strong ensuring users who cannot perceive color differences still receive the same information. Appointment booking step indicators use both color fills and numbered labels to show progress.

A minimum contrast ratio of 4.5:1 is maintained between foreground text and background surfaces across all components and pages. The deep navy primary color #1E3A8A used on white and light gray backgrounds consistently exceeds this threshold. The amber-colored quick reply buttons in the Chatbot interface use dark amber text on a light amber background, maintaining the required contrast ratio. A ratio of 3:1 is applied for large text elements such as the Homepage hero headline, section headings, and the Appointment page hero title.

All background decorative elements used in the Homepage hero section and the Appointment booking hero banner, such as the circular overlay shapes, are marked as purely decorative and are hidden from assistive technologies so they do not clutter the screen reader experience.

2. Operable

All interactive elements across the entire application are fully operable via keyboard input alone without requiring a mouse. This includes the sticky Navbar navigation links, the search bar, category cards on the Homepage, the product grid, sidebar filter controls including the price range slider and color swatches on the Product Listing page, cart drawer quantity controls, the lens type dropdown on the Product Detail page, the wishlist heart button, the multi-step Checkout form, the Login and Signup forms, all tab navigation buttons on the User Profile page, the four-step Appointment booking wizard including the time slot grid and doctor selection cards, and the Chatbot floating button and quick reply chips.

A logical and consistent tab order is maintained across all pages in accordance with the visual reading order. Users navigating via keyboard can move sequentially through the Navbar, main content area, and Footer without encountering unexpected focus jumps or keyboard traps. On the Product Listing page, keyboard users can navigate through the sidebar filters and product grid in a natural top-to-bottom, left-to-right order.

Visible focus indicators are applied to all focusable elements throughout the system, including buttons, links, text inputs, dropdowns, checkboxes, radio-style selections, and time

slot grid buttons on the Appointment page. The Appointment booking wizard's Continue button is programmatically disabled when required fields are incomplete, preventing accidental progression and providing clear feedback.

The Cart Drawer, which slides in from the right side of the screen, traps focus within the drawer while it is open and returns focus to the cart bag icon in the Navbar when it is closed, preventing users from accidentally interacting with the background content. The Chatbot window similarly traps focus within the chat panel while open and returns focus to the floating chat bubble when closed. The four-second automatic redirect on the Order Confirmation screen is supplemented with a visible manual navigation link so users who need more time are not disadvantaged.

3. Understandable

All form inputs across the Signup, Login, Checkout, and Appointment booking pages are associated with clearly visible and descriptive labels positioned above their respective input fields. Required fields are identified both visually with an asterisk marker and programmatically using `aria-required="true"` so that screen readers announce them before the user attempts to submit.

Inline error messages are displayed directly adjacent to the relevant input field and linked programmatically using `aria-describedby`, enabling screen readers to announce the specific error immediately upon focus. These include the password mismatch error on the Signup page, the empty field error on the Login page, the incomplete field validation on each step of the Checkout form, and the incomplete field and incomplete doctor or time slot selection errors on the Appointment booking wizard.

The live password strength meter on the Signup page is implemented with a visible text label in addition to the colored bar, ensuring the feedback is communicated to all users regardless of color perception. On the Appointment booking page, the Continue button includes a tooltip-style indicator when it is disabled, explaining which fields are still required rather than leaving users uncertain why they cannot proceed.

The Chatbot quick reply buttons use clear, plain-language labels such as Frame recommendations, Track my order, Opening hours, Our services, and Location and contact, ensuring users understand exactly what each option will do before selecting it. The bot's

scripted responses are written in plain conversational language appropriate for all literacy levels.

The three-step Checkout progress bar and the four-step Appointment booking progress bar both use numbered step indicators alongside descriptive step labels — Your Details, Choose Doctor, Date and Time, and Review and Confirm — so users always understand where they are within the process and how many steps remain.

4. Robust

The Next.js frontend uses semantic HTML5 elements consistently throughout all pages of the system. This includes `<nav>` for the sticky Navbar, `<main>` for all page content areas, `<section>` for the Homepage content sections including the hero, categories, featured products, and promo banners, `<form>` for all input forms across Login, Signup, Checkout, and Appointment booking, `<button>` for all interactive controls, and `<ul>` and `<li>` for the product grid and navigation link lists. This semantic structure ensures compatibility with major screen readers and assistive technologies including NVDA and browser-native tools.

Dynamic content updates that occur without a full page reload are implemented using aria-live regions so that assistive technologies announce the changes to users. These live regions cover the cart badge count on the Navbar when items are added or removed, the real-time credit card preview updates on the Checkout payment step, the password strength meter feedback on the Signup page, the product grid updates when filters are applied or changed on the Product Listing page, the Chatbot bot response messages as they appear after a user selects a quick reply, the typing indicator animation in the Chatbot window, and the Order Confirmation screen content after a successful order is placed.

The Cart Drawer is implemented as a modal dialog using `role="dialog"` and `aria-modal="true"`, with an accessible name provided via aria-labeled pointing to the drawer heading. The Chatbot window is similarly implemented with `role="dialog"` and `aria-modal="true"` so screen readers correctly scope their reading to the chat panel while it is open.

The doctor selection cards on the Appointment booking Step 2 use `role="radio"` and `aria-checked` attributes to communicate the selected state to assistive technologies, since they function as a custom radio group. The time slot buttons on Step 3 use `aria-pressed` to indicate whether a slot is selected. The multi-step progress indicators on both the Checkout and

Appointment pages use `aria-current="step"` on the active step so screen readers announce the current position within the process.

Role-restricted UI elements, such as the Checkout button being unavailable to guest users until they log in, and the Continue buttons on the Appointment form being unavailable until required fields are completed, are communicated using `aria-disabled="true"` with a descriptive tooltip rather than being silently hidden or removed from the DOM.

Additional Considerations

The interface supports browser-level text scaling up to 200% without loss of content or functionality, in accordance with WCAG 2.1 Success Criterion 1.4.4. All responsive layouts across mobile, tablet, and desktop viewports reflow correctly at increased text sizes without horizontal scrolling, content truncation, or element overlap. This has been verified for the Navbar collapsing into the mobile hamburger menu, the product grid reflowing from three columns to a single column, the Appointment time slot grid adjusting from four columns to three, and the Chatbot window remaining fully usable at increased text sizes.

The Chatbot floating button at the bottom-right corner of the screen includes a visible pulsing amber indicator dot to draw attention to its presence. This indicator uses both color and animation to communicate availability. Users who have enabled reduced motion preferences via their operating system will see the animation suppressed in accordance with the `prefers-reduced-motion` media query, ensuring the interface does not cause discomfort for users with vestibular disorders. Animated elements elsewhere in the system, including the Homepage hero fade-up animations and the floating card animation, also respect this preference.

The Appointment booking confirmation screen displays the full booking summary including patient name, selected doctor, date, time, and the fixed Minuwangoda Branch location in a structured list format that screen readers can navigate efficiently. The booking reference number is rendered in a monospace font for clarity and is accessible to screen readers.

The mobile navigation drawer, which opens from the hamburger menu button in the Navbar on small screens, is implemented with focus trapping and an accessible close button, ensuring keyboard and screen reader users can open, navigate, and close the mobile menu without difficulty. When the mobile menu is open, background content is inert and not reachable by keyboard or screen reader until the menu is dismissed.

Chapter 6: Security Design

6.1 Authentication Mechanism

OSMS employs a Stateless Authentication Mechanism using JSON Web Tokens (JWT). This approach ensures secure communication between the React.js frontend and the Node.js/Express.js backend while maintaining high scalability across cloud instances.

A. Core Technology & Standards

1. JWT (JSON Web Token): Used for creating secure access tokens for authenticated users.
2. Bcrypt.js: A password-hashing function used to salt and hash passwords before storing them in the MongoDB database, ensuring that plain-text passwords are never saved.
3. HTTP Only Cookies / Authorization Headers: Tokens are securely stored and transmitted to prevent Cross-Site Scripting (XSS) attacks.

B. Authentication Workflow

1. User Login: The user (Customer or Staff) provides credentials (Email and Password) via the React frontend.
2. Password Verification: The backend retrieves the hashed password from MongoDB and uses Bcrypt to compare it with the provided input.
3. Token Generation: Upon successful verification, the backend generates a JWT containing the User_ID and Role (e.g., Admin, Optometrist).
4. Token Transmission: The token is sent back to the client and stored in the browser's local storage or a secure cookie.
5. Subsequent Requests: For every protected action (e.g., booking an appointment), the frontend includes the JWT in the HTTP Authorization Header as a Bearer token.
6. Token Validation: The backend validates the token's signature using a Secret Key stored in the environment variables before granting access to the requested resource.

C. Session Management & Security

- Token Expiry: Tokens are set to expire after a predefined duration (e.g., 24 hours) to minimize the risk of token theft.

- **Logout Mechanism:** Upon logout, the front end clears the token, effectively terminating the session without requiring a database call.

6.2 Authorization Levels

OSMS implements Role-Based Access Control (RBAC) to enforce security boundaries. Access permissions are strictly aligned with the Functional Requirements (FR) and the designated sources for each requirement.

A. Defined User Roles and Permissions

1. **System Administrator:**
 - **Primary Responsibility:** System integrity and security.
 - **Permissions:** Managing user registration and secure authentication (FR-001). Full oversight of system configurations.
2. **Inventory Manager:**
 - **Primary Responsibility:** Stock accuracy and supply chain management.
 - **Permissions:** Maintaining real-time stock levels across all branches (FR-005) and managing automated re-order alerts (FR-006).
3. **Branch Manager:**
 - **Primary Responsibility:** Branch operations and retail performance.
 - **Permissions:** Maintaining digital product catalogs and filters (FR-003). Dispatching automated appointment reminders (FR-008).
4. **Optometrist / Medical Staff:**
 - **Primary Responsibility:** Clinical services and patient care.
 - **Permissions:** Facilitating online appointment bookings via the interactive calendar (FR-007). Recording and securely storing clinical prescription data (FR-013).
5. **Management (Owner):**
 - **Primary Responsibility:** Business analytics and financial oversight.

- Permissions: Monitoring integrated payment gateways (FR-009). Reviewing automated loyalty point updates (FR-010). Accessing comprehensive sales and inventory reports (FR-012).

6. Customer (External User):

- Primary Responsibility: End-user engagement.
- Permissions: Managing personal profiles and viewing prescription history (FR-002). Utilizing the shopping cart and checkout (FR-004). Interacting with the AI chatbot (FR-011). Tracking order delivery status (FR-014).

B. Updated Access Control Matrix

Table 12: Updated Access Control Matrix Table

Requirement ID	Functional Requirement	Admin	Inv. Manager	Branch Manager	Optometrist	Management	Customer
FR-001	User registration and authentication	Owner	No	No	No	No	No
FR-002	Profile management & prescription history	View	No	No	View	No	Owner
FR-003	Digital product catalogs & filters	View	View	Owner	No	View	View

FR-004	Shopping cart & checkout	No	No	No	No	No	Owner
FR-005	Real-time stock synchronization	No	Owner	View	No	View	No
FR-006	Automated inventory re- order alerts	No	Owner	View	No	View	No
FR-007	Online appointment booking calendar	View	No	View	Owner	No	Use
FR-008	Automated appointment reminders	No	No	Owner	View	No	Receive
FR-009	Secure payment gateway processing	No	No	No	No	Owner	Use
FR-010	Loyalty points calculation/upd ates	No	No	No	No	Owner	View

FR-011	AI-driven chatbot assistance	No	No	No	No	No	Owner
FR-012	Comprehensive sales/inventory reports	No	View	View	No	Owner	No
FR-013	Clinical prescription data recording	No	No	No	Owner	No	View
FR-014	Real-time order tracking status	No	View	View	No	No	Owner

Legend for Access Control Matrix

- Owner (O): Represents the primary actor with the authority to execute the requirement or input/modify the associated data.
- View (V): Grants read-only access to the data. For example, a customer can view their own prescription history, but only an Optometrist has the authority to modify it.
- Use (U): Indicates permission to utilize a specific system feature or interface, such as a customer interacting with the appointment booking calendar.

No (-): Indicates that the user role has no access or permission for the specified functional requirement.

6.3 Data Protection Approach

The OSMS adopts a comprehensive data protection strategy to ensure the Confidentiality, Integrity, and Availability (CIA) of sensitive business and medical records. This approach is

aligned with the Personal Data Protection Act (PDPA) of Sri Lanka and international security standards.

A. Core Protection Strategies

- Principle of Least Privilege (PoLP): Access to sensitive data is restricted to the minimum level necessary for a user to perform their job functions. For instance, Inventory Managers cannot access clinical prescription data.
- Data Masking and Anonymization: In analytical reports for Management (FR-012), personally identifiable information (PII) is masked to protect customer privacy while providing necessary business insights.
- Secure Audit Trails: The system maintains immutable logs of all critical actions, such as stock adjustments, financial transactions, and clinical data modifications. These logs are retained for a minimum of seven years for regulatory auditing.
- Automated Backup and Recovery: To prevent data loss (RSK-001), automated daily backups of the MongoDB Atlas database and Amazon S3 buckets are performed. These backups are stored in separate cloud region to ensure disaster recovery.

B. Database Security

- Network Isolation: The MongoDB Atlas database is hosted within a Virtual Private Cloud (VPC), accessible only via a secure IP whitelist and dedicated peering connections from the AWS Application Layer.
- Database Authentication: Access to the database is managed through strictly controlled credentials and Identity and Access Management (IAM) roles, ensuring no direct public access to data tiers.

C. Data Retention and Disposal

- Retention Policy: Medical and clinical data (FR-013) are retained for 24 months for active prescription validity. Historical records are archived for 7 years to comply with statutory legal requirements.
- Secure Disposal: Once the retention period expires, data is securely purged from the active database and backup archives using industry-standard wiping protocols to ensure it cannot be reconstructed.

6.4 Input Validation and Sanitization Strategy

To protect the OSMS against malicious data entry and ensure data integrity, a multi-layered validation and sanitization strategy is implemented at both the Client-side (Frontend) and Server-side (Backend). This ensures that only well-formed and safe data reaches the database.

A. Client-Side Validation (Frontend)

- **Real-time Validation:** The React.js frontend performs immediate validation using HTML5 attributes and JavaScript to provide instant feedback to the user.
- **Data Typing:** Ensures that numerical fields (e.g., price, LKR amount) do not accept alphabetic characters and that email fields follow the standard email format.
- **Constraint Enforcement:** Enforces minimum and maximum length constraints for text fields, such as customer names and passwords.

B. Server-Side Validation (Backend)

- **Schema Validation:** The Node.js/Express.js backend uses the Joi or Validator.js library to validate incoming JSON payloads against pre-defined schemas before processing.
- **Business Rule Validation:** Verifies that inputs comply with specific business logic, such as ensuring an eye examination booking is made at least 24 hours in advance.
- **Authorization Check:** Validates that the user has the necessary permissions (RBAC) to perform the specific action requested by the input.

C. Data Sanitization (Protection against Injections)

- **NoSQL Injection Prevention:** Since the system utilizes MongoDB, all inputs are sanitized to prevent NoSQL injection attacks by ensuring that query operators (e.g., \$gt, \$ne) are stripped from user-provided strings.
- **XSS (Cross-Site Scripting) Prevention:** All string inputs are sanitized to escape or remove HTML tags and malicious scripts before they are stored in the database or rendered back to the UI.
- **Trim and Case Normalization:** Inputs are trimmed of leading/trailing whitespace and normalized (e.g., converting emails to lowercase) to ensure data consistency.

6.5 Encryption Standards for Data at Rest and in Transit

OSMS implements industry-leading encryption standards to protect sensitive information, such as clinical prescriptions (FR-013) and personal user data (FR-001, FR-002), from unauthorized access during both storage and transmission.

A. Encryption for Data in Transit (Symmetric & Asymmetric)

Data "in transit" refers to information moving between the React.js frontend and the Node.js backend over the internet.

- **Protocol:** All communications are secured using HTTPS (Hypertext Transfer Protocol Secure) based on TLS 1.2 or higher (Transport Layer Security).
- **Mechanism:** This ensures that any data packets intercepted during transmission remain unreadable to attackers, preventing Man-in-the-Middle (MitM) attacks.
- **API Security:** All RESTful API calls exchange data in JSON format, which is encapsulated within the TLS-encrypted tunnel.

B. Encryption for Data at Rest (Symmetric)

Data "at rest" refers to information stored permanently in the database or cloud storage.

- **Database Encryption:** MongoDB Atlas (on AWS) utilizes AES-256 (Advanced Encryption Standard with a 256-bit key) to encrypt the physical storage media where user records and transaction logs are kept.
- **Object Storage:** Media assets, such as digital prescription scans and eyewear images stored in Amazon S3, are encrypted using Server-Side Encryption (SSE-S3 or SSE-KMS) based on AES-256.
- **Credential Hashing:** While not strictly encryption, all user passwords are transformed into irreversible cryptographic hashes using the Bcrypt algorithm before being stored, ensuring that even administrators cannot view plain-text passwords.

C. Key Management

- **AWS KMS:** Cryptographic keys used for encryption are managed through AWS Key Management Service (KMS), which provides secure key storage, rotation, and access control.

- Environment Variables: Sensitive application secrets (e.g., JWT secret keys, Database URIs) are never hard-coded and are managed through secured environment variables within the hosting environment.

Chapter 7: Deployment Design

The OSMS follows a cloud-native deployment strategy using Amazon Web Services (AWS). This design is optimized for high availability (99.9%), cost-efficiency, and seamless integration with the MERN stack architecture. By utilizing serverless and managed services, the system reduces the operational overhead for Darshana Optical.

7.1 Hosting Plan

The OSMS infrastructure is designed for high availability, enterprise-grade security, and seamless scalability to handle the operational load of Darshana Optical (Pvt) Ltd. The hosting strategy follows a distributed architecture to ensure no single point of failure.

1. Frontend Hosting (Edge Delivery)

- Platform: Vercel (Pro/Enterprise Tier)
- Implementation: The React.js frontend is deployed on Vercel to leverage its global Edge Network.
- Justification: This ensures sub-second page load times across all branches in Sri Lanka. It provides built-in CI/CD, SSL management, and DDoS protection (WAF) at the edge.

2. Backend API Hosting (Serverless Containers)

- Platform: AWS App Runner or AWS ECS (Elastic Container Service) on Fargate
- Implementation: The Node.js/Express.js backend is containerized using Docker and deployed as a managed service.
- Justification: This eliminates server management (Serverless) and provides auto-scaling based on CPU/Memory usage. It seamlessly handles the 50% increase in concurrent transactions as defined in the SRS.

3. Database Hosting (Managed Cloud Database)

- Platform: MongoDB Atlas (Dedicated Cluster - M10+ Tier)
- Implementation: A fully managed, multi-region database cluster hosted on AWS infrastructure.

- Justification: Provides VPC Peering for secure connection to the backend, automated point-in-time recovery (backups), and high availability through replica sets. This ensures real-time inventory synchronization (FR-005) with 99.9% uptime.

4. Media & Object Storage (High Durability)

- Platform: Amazon S3 (Standard + Intelligent-Tiering)
- Implementation: High-resolution eyewear catalogs and encrypted clinical prescription scans (FR-013) are stored here.
- Justification: S3 provides 99.999999999% (11 nines) of durability. S3 Intelligent-Tiering is configured to move archived prescriptions (older than 2 years) to cost-effective storage classes, meeting the 7-year data retention policy efficiently.

5. Scaling and Cost Management (Pay-as-you-go)

- Model: The architecture utilizes a Pay-as-you-go model. While initial development utilizes Free Tier limits where applicable, the production environment is configured to scale resources dynamically.
- Optimization: Costs are managed through AWS Budgets and Vercel Usage Analytics, ensuring that infrastructure expenses grow only in proportion to the business's transaction volume.

7.2 Hardware Requirements

OSMS is a cloud-native platform, eliminating the need for on-premise server hardware at Darshana Optical branches. However, to ensure optimal performance and fulfill the operational requirements defined in the SRS, the following client-side hardware is required.

1. Staff and Administrative Terminals

- Device Type: Desktop PCs, Laptops, or high-end Tablets (iPad/Android).
- Processor: Quad-core 2.0 GHz or higher to maintain a <2s response time.
- Memory (RAM): Minimum 8GB for smooth multitasking between inventory management and clinical records.
- Display: 1080p Full HD monitor for clear visualization of eyewear catalogs and diagnostic reports.

2. Clinical Operations (Optometrist Room)

- Prescription Digitization: High-resolution scanners or integrated cameras to capture and upload digital copies of physical prescription notes.
- Tablets: Portable tablets are recommended for Optometrists to record eye test data directly during consultations.

3. Retail and Inventory Peripherals

- Barcode Scanners: USB or Bluetooth-enabled scanners for real-time SKU tracking and inventory updates (FR-005).
- Receipt Printers: Thermal printers integrated with the web portal for generating instant sales invoices at the point of sale.

4. Network Infrastructure

- Router/Gateway: High-speed Dual-band Wi-Fi routers.
- Connectivity: Minimum 10 Mbps stable broadband connection to support real-time database synchronization across multiple locations.

7.3 Network Diagram

The network architecture of the OSMS is designed using a Hybrid Cloud model, ensuring secure communication between the frontend (Vercel Edge Network), the backend (AWS VPC), and the managed database (MongoDB Atlas). This multi-layered approach protects sensitive prescription data while providing high-speed access to users across all branches.

A. Network Components and Flow

1. Public Web Tier (External):
 - Vercel Edge Network: Hosts the React.js frontend, providing global DDoS protection and SSL termination.
 - Public Internet: Customers and staff access the system via secure HTTPS (TLS 1.2+).
2. Application Tier (AWS Virtual Private Cloud - VPC):
 - API Gateway / Load Balancer: Acts as the entry point for the Node.js backend, routing traffic from the Vercel frontend.

- Private Subnet: Contains the AWS ECS/App Runner instances. This layer is isolated from the public internet and only accepts traffic from the frontend origin.

3. Data Tier (Managed Database):

- MongoDB Atlas: Connected to the AWS VPC via VPC Peering or Private Link. This ensures that database traffic never travels over the public internet, maintaining high data integrity.

B. Connectivity Logic

- Secure API Communication: All communication between the frontend and backend is facilitated through RESTful APIs using JSON format.
- Third-party Integrations: Secure outbound connections are established to external services like PayHere for payments and Twilio/Nodemailer for automated SMS/Email reminders.

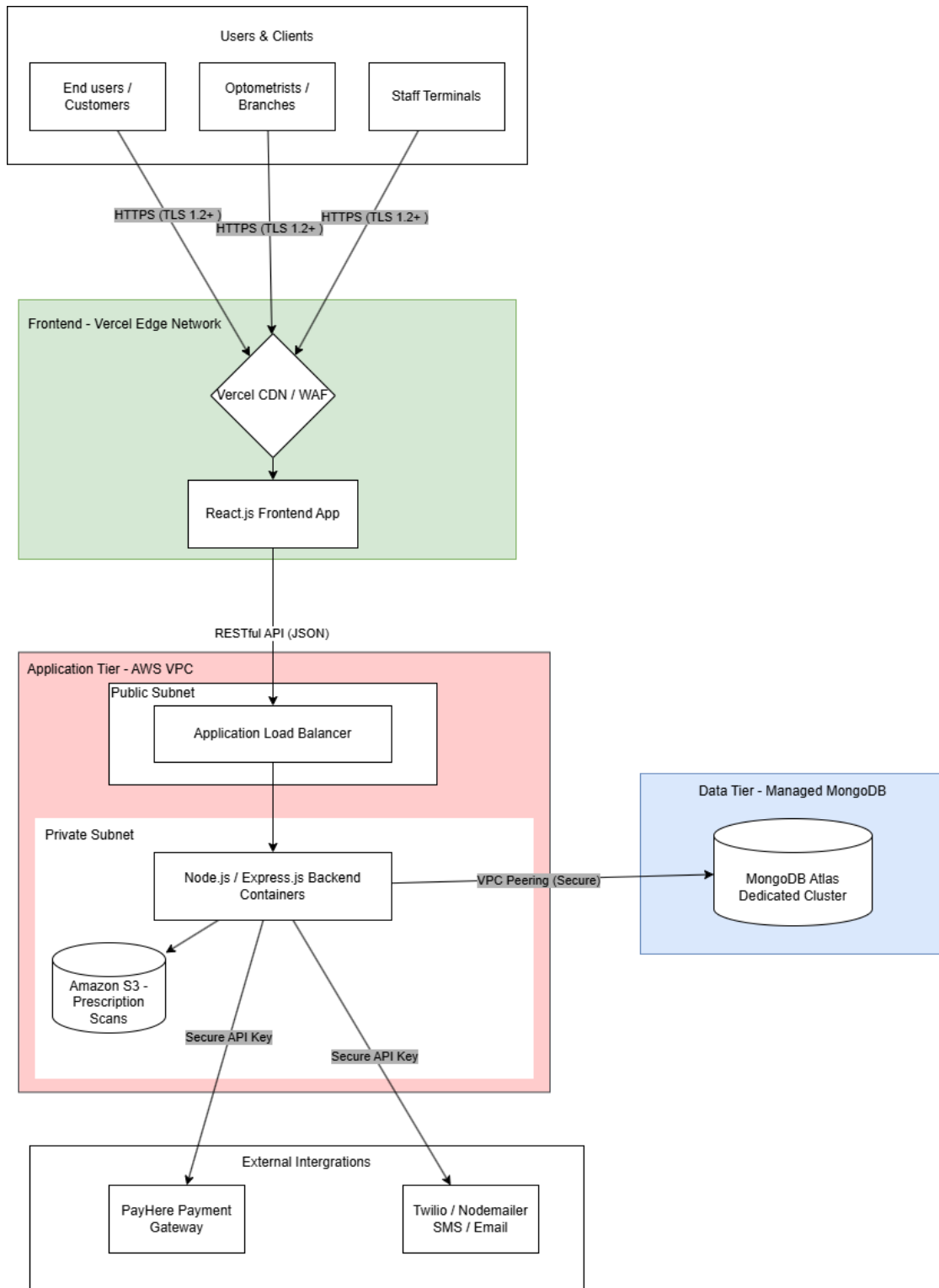


Figure 41: Network Diagram

7.4 Environment Specification

To ensure software stability, security, and consistent performance (NFR-001, NFR-002), the OSMS is managed across three distinct environments. This segregation prevents untested code from affecting live business operations at Darshana Optical.

1. Development Environment (Dev)

- Purpose: Used by developers for active feature implementation, bug fixing, and unit testing.
- Frontend: Localhost or private Vercel preview branches.
- Backend: Local Node.js server with environment variables pointed to a development database.
- Database: A separate "Development" collection in MongoDB Atlas to ensure no real data is modified during experiments.

2. Staging Environment (UAT - User Acceptance Testing)

- Purpose: A replica of the production environment used for final testing and university project evaluations.
- Frontend: Hosted on a dedicated staging URL (e.g., staging.darshanaopticals.lk) via Vercel.
- Backend: Deployed on AWS App Runner with configurations identical to the production environment.
- Database: A "Staging" database containing anonymized or mock data, used to verify business rules such as appointment lead times (10.1) and discount applications (10.2).

3. Production Environment (Prod)

- Purpose: The live system accessed by real customers, staff, and management for daily operations.
- Frontend: The primary domain (e.g., www.darshanaopticals.lk) served through Vercel's global CDN for maximum speed.
- Backend: High-availability deployment on AWS ECS Fargate with auto-scaling enabled.
- Database: The primary MongoDB Atlas Dedicated Cluster (M10+) with automated backups and 24/7 monitoring to ensure 99.9% uptime (NFR-002).

Environment Comparison Table

Table 13: Environment Comparison Table

Feature	Development	Staging (UAT)	Production (Live)
Accessibility	Local / Internal Team	QA Team & Project Supervisors	Public Customers & Staff
Data Type	Mock / Dummy Data	Anonymized Test Data	Real Patient & Sales Data
Security	Basic Credentials	JWT + SSL (Same as Prod)	Full RBAC + SSL + PDPA Compliance
CI/CD Trigger	Feature Branch Push	Pull Request to Main	Release Tag / Approval

7.5 CI/CD Pipeline Overview

OSMS utilizes an automated CI/CD Pipeline managed through GitHub Actions to ensure seamless software delivery and high maintainability. This automated process reduces manual deployment errors and ensures that every code change is thoroughly tested before reaching the production environment.

A. Pipeline Stages

1. Continuous Integration (CI):

- Source Control: Developers push code to specific branches (e.g., feature/*, staging, main).
- Automated Testing: Upon each push, GitHub Actions triggers a suite of unit tests and integration tests to ensure new changes do not break existing functionalities.

- Linting & Quality Checks: The code is scanned for syntax errors and compliance with project coding standards.

2. Continuous Deployment (CD):

- Dockerization: For successful builds, the system automatically creates a new Docker Image for the backend.
- Registry Upload: The image is pushed to Amazon ECR (Elastic Container Registry).
- Automated Deployment:
 - Staging: Merges to the staging branch are automatically deployed to the Vercel (Frontend) and AWS App Runner (Backend) staging environments for UAT.
 - Production: Approved mergers to the main branch trigger a "Rolling Update" on AWS ECS Fargate, ensuring zero downtime for customers and staff.

B. Key Benefits for OSMS

- Rapid Bug Fixes: Enables the development team to meet the performance metric of implementing and deploying 90% of minor bug fixes within 24 hours.
- Version Control & Auditability: Every deployment is logged and associated with a specific version number, ensuring a clear audit trail for university standards.
- Reduced Risk: Automated rollbacks are configured to revert to the previous stable version if the new deployment fails health checks.

Chapter 8: References

- [1] Nielsen Norman Group, “User Interface Design Guidelines,” [Online]. Available: <https://www.nngroup.com/>. [Accessed: Apr. 19, 2026].
- [2] Interaction Design Foundation, “User Experience (UX) Design Basics,” [Online]. Available: <https://www.interaction-design.org/>. [Accessed: Apr. 19, 2026].
- [3] Martin Fowler, *Patterns of Enterprise Application Architecture*. Boston, MA, USA: Addison-Wesley, 2002.
- [4] Amazon Web Services, “Overview of Cloud-Native Architecture,” [Online]. Available: <https://aws.amazon.com/>. [Accessed: Apr. 19, 2026].
- [5] Abraham Silberschatz, Henry F. Korth, and S. Sudarshan, *Database System Concepts*, 6th ed. New York, NY, USA: McGraw-Hill, 2010.
- [6] Object Management Group, “Unified Modeling Language (UML),” [Online]. Available: <https://www.omg.org/>. [Accessed: Apr. 19, 2026].
- [7] National Institute of Standards and Technology, “Advanced Encryption Standard (AES),” [Online]. Available: <https://www.nist.gov/>. [Accessed: Apr. 19, 2026].
- [8] Internet Engineering Task Force, “The Transport Layer Security (TLS) Protocol,” [Online]. Available: <https://www.ietf.org/>. [Accessed: Apr. 19, 2026].
- [9] World Wide Web Consortium, “Web Content Accessibility Guidelines (WCAG) 2.1,” [Online]. Available: <https://www.w3.org/>. [Accessed: Apr. 19, 2026].
- [10] Stripe, “Online Payment Processing,” [Online]. Available: <https://stripe.com/>. [Accessed: Apr. 19, 2026].